



密码学基础

01 密码学概述

02 密码学发展三大阶段

03 历史上那些经典密码

04 密码学基础：进制与计量

05 加解密基础操作：移位和置换



06 对称加密算法(DES 3DES AES RC)

07 非对称/公钥加密算法(RSA DH ECC)

08 数字签名

09 数字证书与CA

10 哈希与HMAC (彩虹表攻击 盐)

11 对称与非对称加密完美融合

12 密码学原理总结



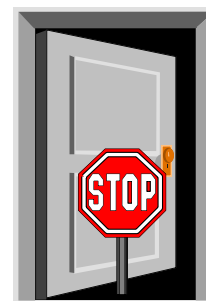
课程目标

- 了解加解密历史，基本概念和相关术语
- 掌握对称加密/非对称加密技术原理和主要算法
- 掌握哈希，HMAC，数字签名，数字证书，CA等技术与概念
- 密码学：网络安全、VPN、区块链技术的基础

信息安全概述

- 信息是当今社会的一种重要资源（数据和信息的对比、信息应用的例子）
- 信息安全的目标：保密性、完整性和不可否认性

- 现代信息系统必须具备有信息安全技术措施
- 信息加密是信息安全的措施之一



进不来



看不懂



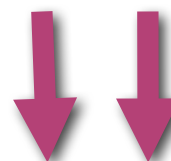
改不了



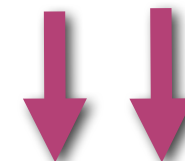
拿不走



跑不掉



保密性



完整性



不可否认性

纸尿裤和啤酒放在一起的强烈刺激两者的销售

数据：甲流。大蒜。板蓝根。口罩。医药股票。

消息：城中村拆迁。盖房子，买房。拿赔偿。

A: 第10题选择A还是B?

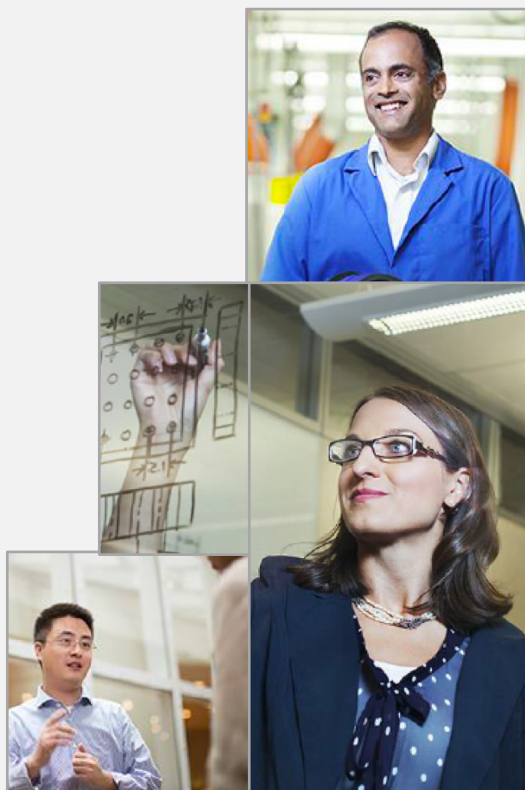
B: 选B, 前面说的是错的。

今年最让我感动的一条新闻。



加解密相关术语

- 明文 也叫明码 (plaintext)
- 密文 (ciphertext)
- 算法 (algorithm)
- 密钥 (key)
- 加密 (encryption)
- 解密 (decryption)
- 公钥 (public key)
- 私钥 (private key)
- 数字签名 (digital signature)
- 证书 (certificate)
- PKI (Public Key Infrastructure)
- HASH HMAC



密码学三大发展阶段

密码学发展阶段

- 1949年之前：密码学是一门艺术
- 1949 ~ 1975年：密码学成为科学
- 1976年以后：密码学的新方向——公钥密码学

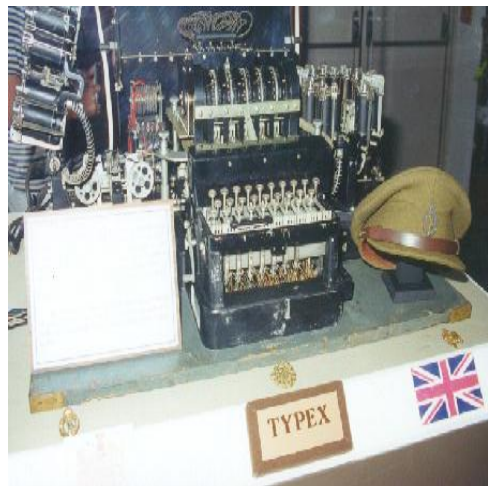
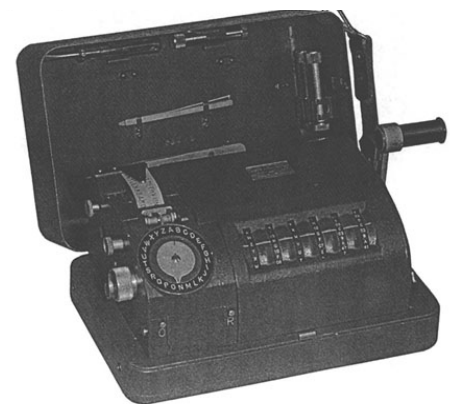
第一阶段：古典密码学

- 密码学还不是科学,而是艺术
- 出现一些密码算法和加密设备
- 密码算法的基本手段出现，针对的是字符
- 简单的密码分析手段出现
- 主要特点：**数据的安全基于算法的保密**



Phaistos圆盘，一种直径约为160mm的Cretan-Minoan粘土圆盘，始于**公元前17世纪**。表面有明显字间空格的字母，至今还没有破解。

20世纪早期密码机



第一阶段：古典密码学

- 1883年Kerchoffs第一次明确提出了编码的原则：加密算法应建立在算法的公开不影响明文和密钥的安全。
- 这一原则已得到普遍承认，成为判定密码强度的衡量标准，实际上也成为传统密码和现代密码的分界线。

第二阶段：1945年-1975年

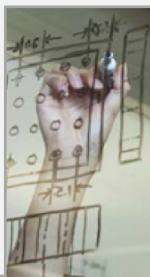
- 计算机使得基于复杂计算的密码成为可能
- 相关技术的发展
 - 1949年Shannon的 “The Communication Theory of Secret Systems”
 - 1967年David Kahn的《The Codebreakers》
 - 1971-73年IBM Watson实验室的Horst Feistel等几篇技术报告
- 主要特点：数据的安全基于密钥而不是算法的保密

第三阶段：1976年-至今

- 1976年：Diffie & Hellman 的 “New Directions in Cryptography” 提出了不对称密钥算法
- 1977年Rivest,Shamir & Adleman提出了RSA公钥算法
- 90年代逐步出现椭圆曲线等其他公钥算法
- 主要特点：公钥密码使得发送端和接收端无密钥传输的保密通信成为可能

第三阶段：1976年-至今

- 1977年DES正式成为标准
- 80年代出现“过渡性”的“Post DES”算法,如IDEA,RCx,CAST等
- 90年代对称密钥密码进一步成熟 Rijndael,RC6, MARS, Twofish, Serpent等出现
- 2001年Rijndael成为DES的替代者



历史那些经典密码

艺术阶段的密码

- 藏头诗
- 不可见墨水
 - 优点：可以应用于通信双方宁愿他们的秘密信息被发现而不愿其中的重要内容丢失的情况
 - 缺点：它需要大量额外的开销来隐藏相对较少的信息

凯撒密码：单表代替密码

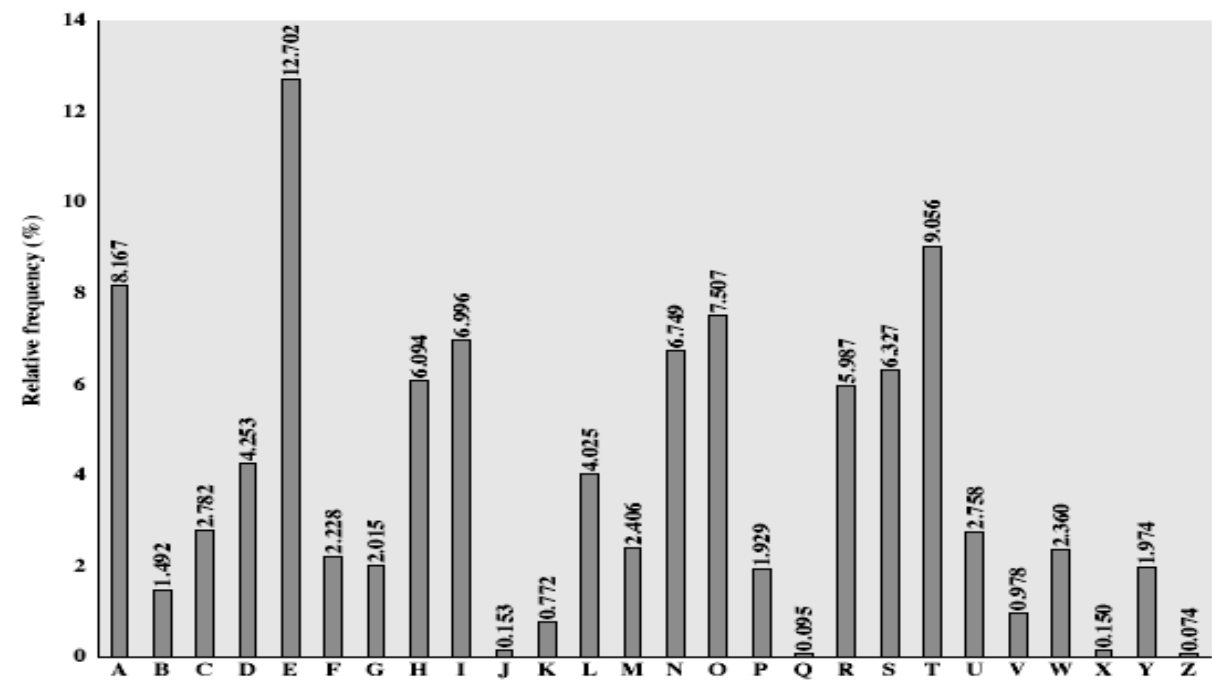
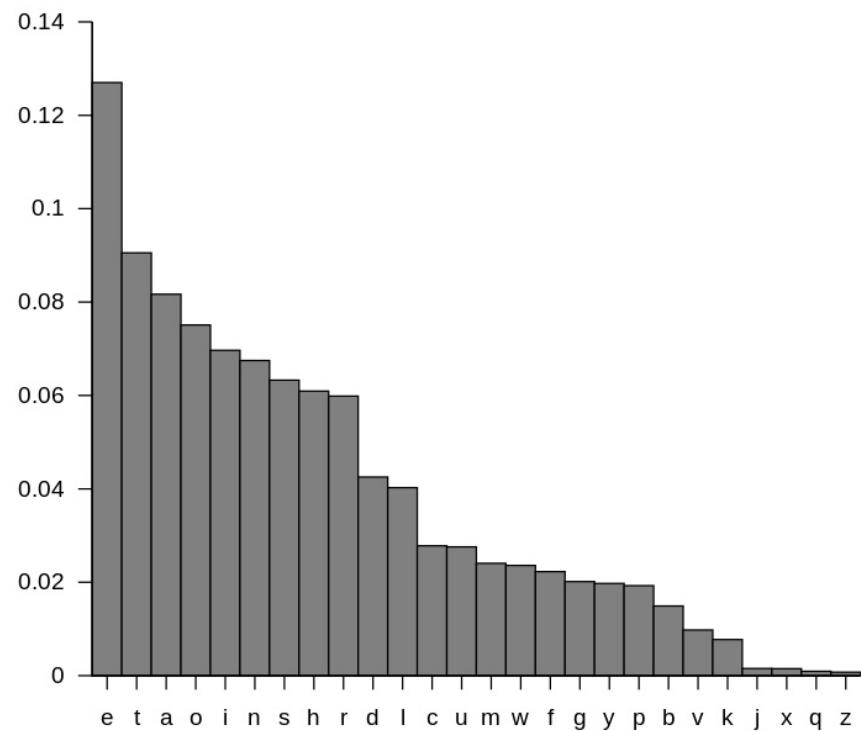
- “凯撒” 密码 古罗马军队用
- 由Julius Caesar发明
- 明文字母 A B C D E F G H I K L M N O P Q R S T V X Y Z
- 密文字母 D E F G H I K L M N O P Q R S T V X Y Z A B C
- 注：拉丁文不用J，U，W

明文：meet me after the toga party

密文：PHHW PH DIWHU WKH WRJD SDUWB

单表代替密码不能掩盖明文语言的所有统计特性！

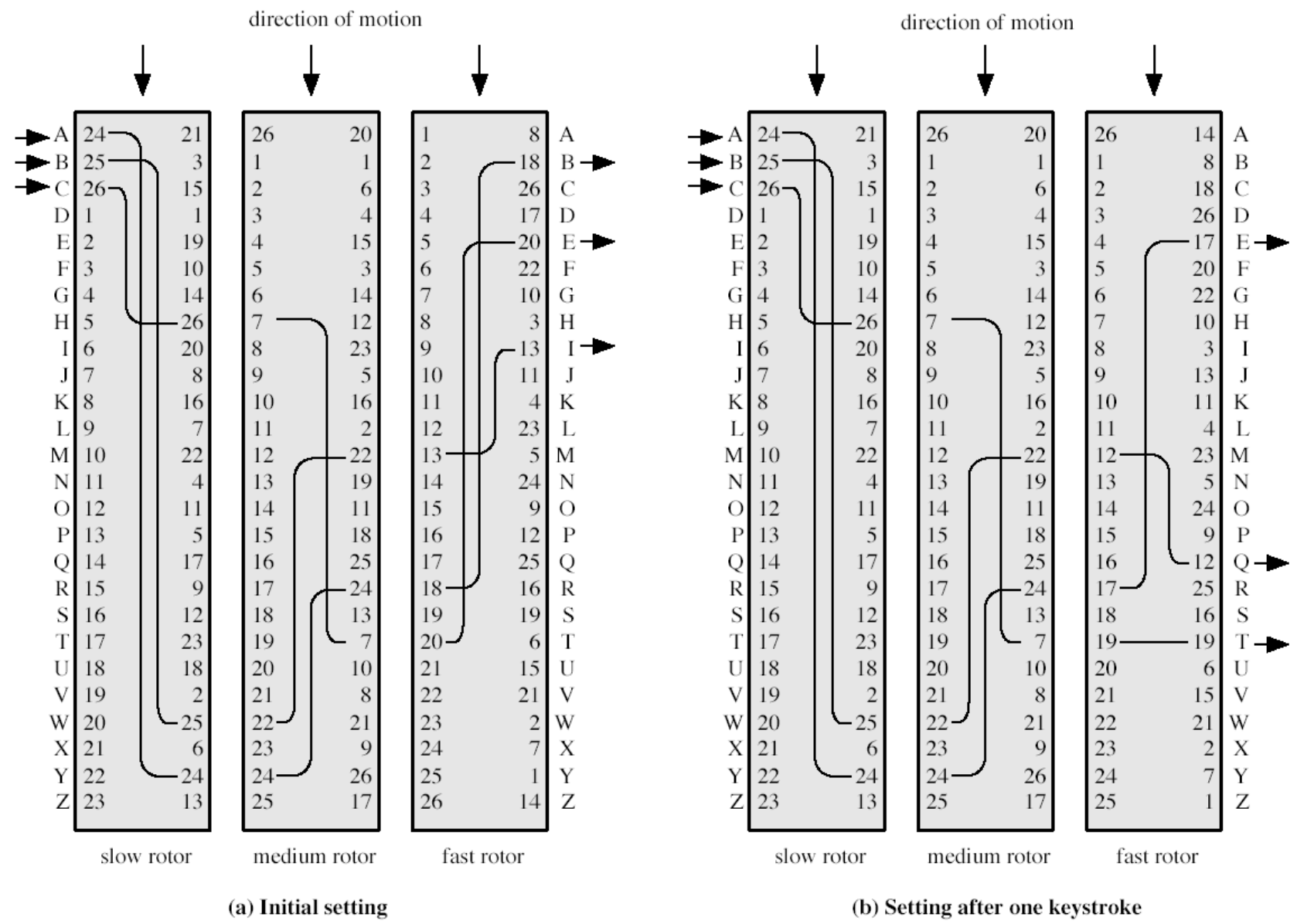
英文字母频率统计



多表替换密码：Playfair Cipher和Hill

- Playfair Cipher
 - 第一次世界大战中英军就使用它作为陆军的标准加密体制，在第二次世界大战中，美军及其他一些盟军用它来进行加密
- Hill密码由数学家Lester S Hill 1929年研制。
 - 在第二次世界大战中，该密码被用来对无线电呼叫信号进行加密，加密和解密均通过机械设备（而非电子设备）来完成
 - 较易被已知明文破解

- 转轮机密码系统（多层加密原理）
- 多筒系统中，操作员每按一次输入键，最后一个转轮就旋转一个引脚的位置。
- 转轮机由一系列独立转动的圆柱体组成，每个圆柱体具有26个输入引脚和26个输出引脚，单个圆柱体定义了一个单字母替代。
- 通过多个加密阶段的组合，能使密码分析变得极为困难
- 对置换和替代都适合

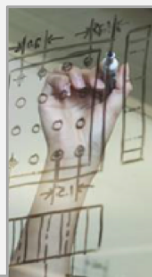


具有连线的三转子机器（用编号的触点表示）

二战中的经典密码



- 德国人恩格玛密码机 (Enigma)
- 图灵三大贡献 (计算机/人工智能/密码学)
- 计算机最高奖项-图灵奖
- 日本人紫码/紫密 (PURPLE)
- 在德国恩格玛机基础上改进
- 美国人 无敌密码
- 也叫纳瓦霍密码(Navajo Code)
- 用印第安语言制作的密码



密码学基础：进制与计量

进制 一种计数方法

- 用有限的数字符号来表示无限的数值，例如阿拉伯数字10进制（0-9）
- 可使用的计数符号数目决定了进位制，简称进制
- 2进制（0，1）计算机机器语言唯一能明白的
- 10进制（0-9）普通人计算常用的
- 16进制（0-9，A,B,C,D,E,F）每一个16进制的字符代表4个二进制组合数字

- 进制间的关系

·		2^0	2^1		2^2				2^3								
·	2进制	0000	0001	0010	0011	0100	0101	0110	0111	1000	1001	1010	1011	1100	1101	1110	1111
·	10进制	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15
·	16进制	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F

- 计算机为什么不用十进制而用二进制？

IP地址换算



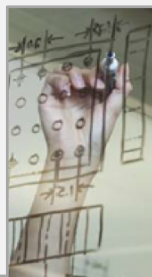
十进制	192.	168.	10.	1
二进制	11000000	10101000	00001010	00000001

幂	2 ⁷	2 ⁶	2 ⁵	2 ⁴	2 ³	2 ²	2 ¹	2 ⁰
	128	64	32	16	8	4	2	1
位	1	1	0	0	0	0	0	0
= 128 + 64 = 192								

计量术语

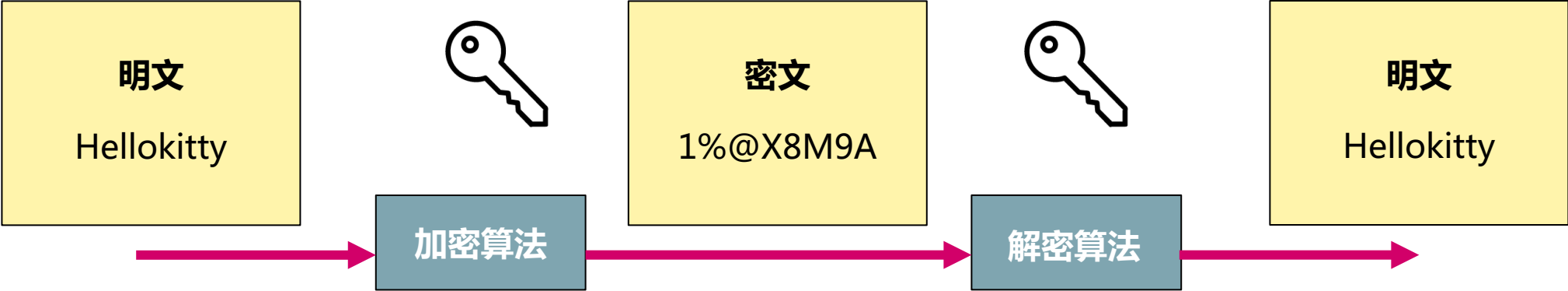
- 位 (bit) 最小的数据单位
- 字节 (Byte) 8个bit组成, 存储空间的最小单位
- K-Kilo, 网络/计算里面 表示千 $1024 (2^{10} \text{次方})$ 存储里面表示1000
 - KB=1024B
- M-Million, 表示百万 (2^{20}次方)
 - MB=1024KB
- G-Giga, 表示10亿 (2^{30}次方)
 - G=1024MB
- T-Tera, 表示10 000亿 (2^{40}次方)
 - TG=1024GB
- P-Peta 表示10 000 000亿 (2^{50}次方) 比特币挖矿算力 8359 PH/s
 - PG=1024T

- 你要大概知道当今计算机的能力上限。也就是说哪些是可以很快算出来的。哪些是不现实的。拿分解质因数来说。你要知道什么样的数是当今计算机分解不了的。个人认为就今天的计算机来说 (今天是20151031)
 - 2的40次方次运算是容易 (easy)。
 - 2的56次方次运算是可做 (feasible)。 2100万枚比特币 = 2^{53}
 - 2的64次方次运算是勉强能做 (barely feasible)。
 - 2的80次方次运算是不能做 (infeasible)。
 - 2的128次方次运算是绝逼不能做 (totally infeasible)。
 - 地球的质量: $5.972 * 10^{24}$ kg
 - 太阳的质量: $1.989 * 10^{30}$ kg
 - 光速: $2.998 * 10^8$ m/s
 - 一光年: $9.460 * 10^{15}$ m
 - 质子的质量: $1.672 * 10^{-27}$ kg
 - 普朗克长度: $1.616 * 10^{-35}$ m



加解密基础操作：移位 置换 编码

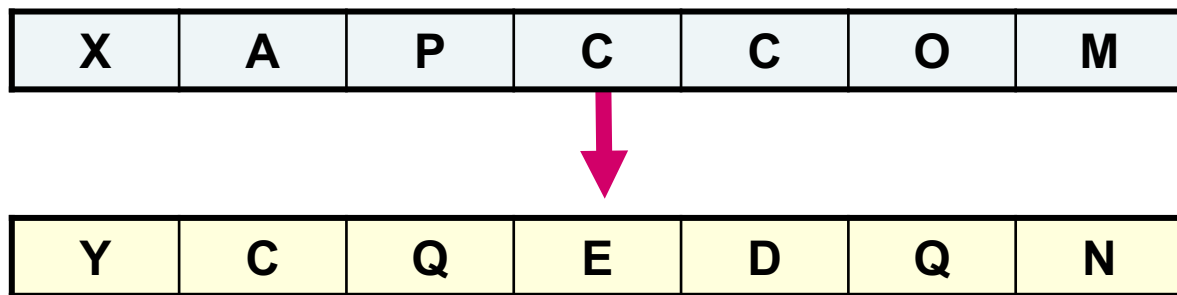
加解密基本操作



- **置换：按照规则替换明文信息**
 - **移位：打乱字母的排列顺序**
 - 移位和置换都是可逆的操作，容易恢复信息
 - 移位、置换应用于现代密码算法中
-
- 加密的实现，不只是依赖以上这些基本的思想，同时也依赖于很多巧妙的设计。
 - 如军事应用中的加密电报，除了使用安全性很高的**编码规则**以外，解密还涉及到收发报文双方的约定。

置换

- 置换是用一个特定的值替换另一个特定值的过程
- 置换需要通信双方事先通知置换的方法
- 置换比较简单，频繁使用会找到规律



- 上例中置换基本原则为：奇数位ASCII码值加1，偶数位ASCII码值加2。

ASCII表																										
(American Standard Code for Information Interchange 美国标准信息交换代码)																										
高四位 低四位		ASCII控制字符											ASCII打印字符													
		0000					0001					0010	0011	0100	0101	0110	0111									
		0					1					2	3	4	5	6	7									
		十进制	字符	Ctrl	代码	转义	字符解释	十进制	字符	Ctrl	代码	转义	字符解释	十进制	字符	十进制	字符	十进制	字符	十进制	字符	十进制	字符	十进制	字符	Ctrl
0000	0	0		^@	NUL	\0	空字符	16	►	^P	DLE		数据链路转义	32		48	0	64	@	80	P	96	`	112	p	
0001	1	1	☺	^A	SOH		标题开始	17	◄	^Q	DC1		设备控制 1	33	!	49	1	65	A	81	Q	97	a	113	q	
0010	2	2	☹	^B	STX		正文开始	18	↕	^R	DC2		设备控制 2	34	"	50	2	66	B	82	R	98	b	114	r	
0011	3	3	♥	^C	ETX		正文结束	19	!!	^S	DC3		设备控制 3	35	#	51	3	67	C	83	S	99	c	115	s	
0100	4	4	♦	^D	EOT		传输结束	20	¶	^T	DC4		设备控制 4	36	\$	52	4	68	D	84	T	100	d	116	t	
0101	5	5	♣	^E	ENQ		查询	21	§	^U	NAK		否定应答	37	%	53	5	69	E	85	U	101	e	117	u	
0110	6	6	♠	^F	ACK		肯定应答	22	—	^V	SYN		同步空闲	38	&	54	6	70	F	86	V	102	f	118	v	
0111	7	7	•	^G	BEL	\a	响铃	23	↕	^W	ETB		传输块结束	39	'	55	7	71	G	87	W	103	g	119	w	
1000	8	8	▣	^H	BS	\b	退格	24	↑	^X	CAN		取消	40	(	56	8	72	H	88	X	104	h	120	x	
1001	9	9	○	^I	HT	\t	横向制表	25	↓	^Y	EM		介质结束	41	)	57	9	73	I	89	Y	105	i	121	y	
1010	A	10	◼	^J	LF	\n	换行	26	→	^Z	SUB		替代	42	*	58	:	74	J	90	Z	106	j	122	z	
1011	B	11	♂	^K	VT	\v	纵向制表	27	←	^[	ESC	\e	溢出	43	+	59	;	75	K	91	[	107	k	123	{	
1100	C	12	♀	^L	FF	\f	换页	28	└	^\	FS		文件分隔符	44	,	60	<	76	L	92	\	108	l	124		
1101	D	13	♪	^M	CR	\r	回车	29	↔	^]	GS		组分分隔符	45	-	61	=	77	M	93	]	109	m	125	}	
1110	E	14	🎵	^N	SO		移出	30	▲	^^	RS		记录分隔符	46	.	62	>	78	N	94	^	110	n	126	~	
1111	F	15	🎵	^O	SI		移入	31	▼	^-	US		单元分隔符	47	/	63	?	79	O	95	_	111	o	127	␣	^Backspace 代码: DEL
注：表中的ASCII字符可以用“Alt + 小键盘上的数字键”方法输入。																										
2013/08/08																										

BASE64编码

Value	Char	Value	Char	Value	Char	Value	Char
0	A	16	Q	32	g	48	w
1	B	17	R	33	h	49	x
2	C	18	S	34	i	50	y
3	D	19	T	35	j	51	z
4	E	20	U	36	k	52	0
5	F	21	V	37	l	53	1
6	G	22	W	38	m	54	2
7	H	23	X	39	n	55	3
8	I	24	Y	40	o	56	4
9	J	25	Z	41	p	57	5
10	K	26	a	42	q	58	6
11	L	27	b	43	r	59	7
12	M	28	c	44	s	60	8
13	N	29	d	45	t	61	9
14	O	30	e	46	u	62	+
15	P	31	f	47	v	63	/

source ASCII (if <128)	M								a								n							
source octets	77 (0x4d)								97 (0x61)								110 (0x6e)							
Bit pattern	0	1	0	0	1	1	0	1	0	1	1	0	0	0	0	1	0	1	1	0	1	1	1	0
Index	19								22				5				46							
Base64-encoded	T								W				F				u							
encoded octets	84 (0x54)								87 (0x57)				70 (0x46)				117 (0x75)							

Base58编码

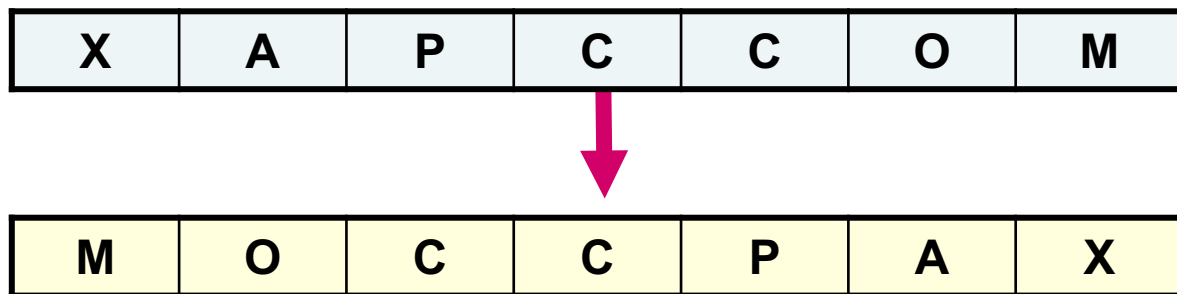
Value	Character	Value	Character	Value	Character	Value	Character
0	1	1	2	2	3	3	4
4	5	5	6	6	7	7	8
8	9	9	A	10	B	11	C
12	D	13	E	14	F	15	G
16	H	17	J	18	K	19	L
20	M	21	N	22	P	23	Q
24	R	25	S	26	T	27	U
28	V	29	W	30	X	31	Y
32	Z	33	a	34	b	35	c
36	d	37	e	38	f	39	g
40	h	41	i	42	j	43	k
44	m	45	n	46	o	47	p
48	q	49	r	50	s	51	t
52	u	53	v	54	w	55	x
56	y	57	z				

0123456JMIJKOPWNUJHTRXZlmnorqerz + /

去掉：0 (零), O (大写字母O), l (大写的字母i) and I (小写的字母L) + /

移位

- 移位：把某个字母以其前或其后几位的某个特定的字母替代
- 移位具有规律，容易被攻破



- 你能分析出以上例子中移位的规律吗？
- 在计算机中，怎样才能自动实现大量复杂数据的加密和解密？
- 这依赖于好的、可被计算机识别的、被验证为有效的 **加密算法**。

加密算法分类

- 密码设计的基本公理和前提是算法公开
- 系统的安全性仅依赖于密钥的保密性
- 加密算法分类
 - 对称密钥密码算法（又称私有密钥算法）
 - 非对称密钥密码算法（又称公钥密码算法）

加密强度对比

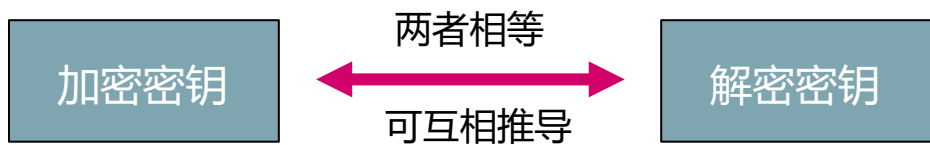
对称密钥	ECC密钥	RSA密钥	攻破时间	内存
56	112	420	小于5分钟	少量
80	160	760	600个月	4G
96	192	1020	300万年	170G
128	256	1620	10E16年	120T



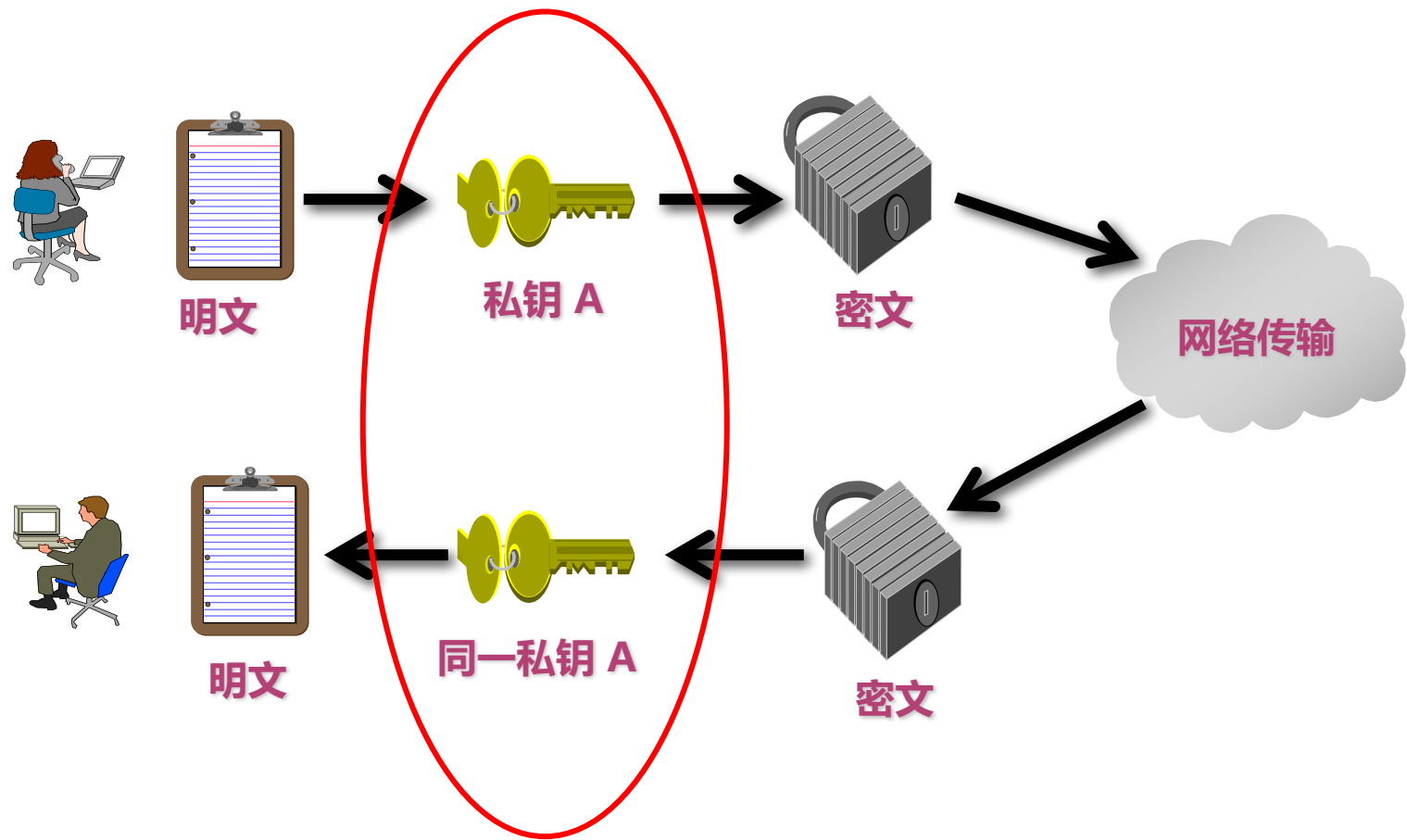
对称加密算法

对称加密算法原理

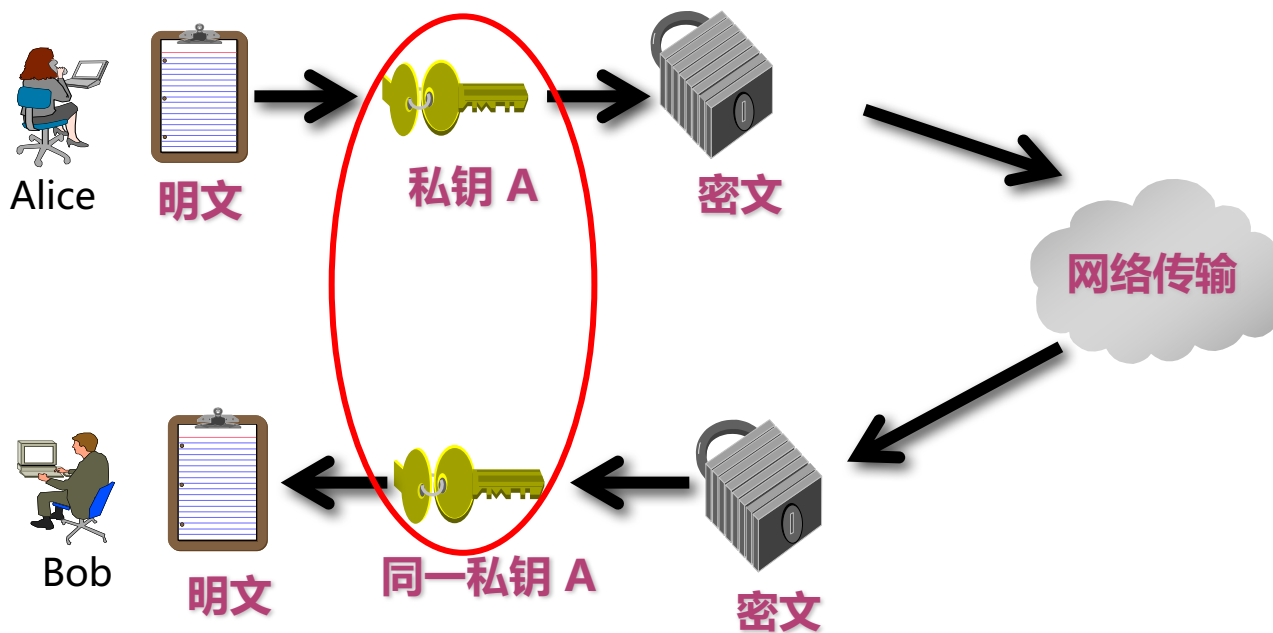
- 对称加密：使用同一密钥进行加密和解密
 - 传统密码加密
 - 私钥算法加密
- 优势：加解密速度快，密文是紧凑的，安全



对称加密算法 加解密过程

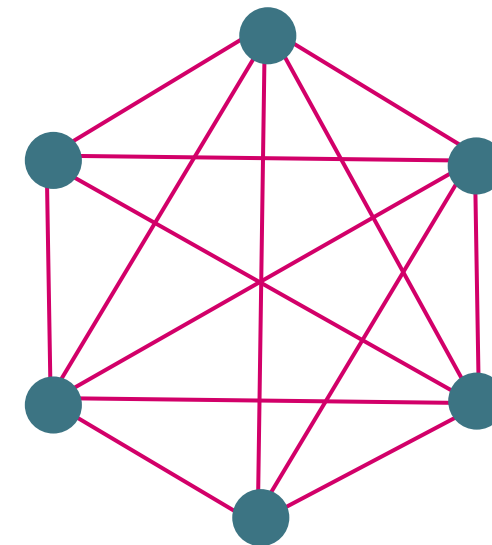


对称加密算法的问题



Alice怎么把密钥传递给Bob？

坐飞机去取？网络传送？打电话？**窃听**



2个人只有一个密钥，6个人则 $6 * (6 - 1) = 30$

100个人密钥数量就是 $100 * (100 - 1)$

而且为了保障安全，每个密钥使用一次后要删除

对称加密算法缺点：密钥分发、密钥存储和管理。缺乏对数字签名/不可否认的支持。

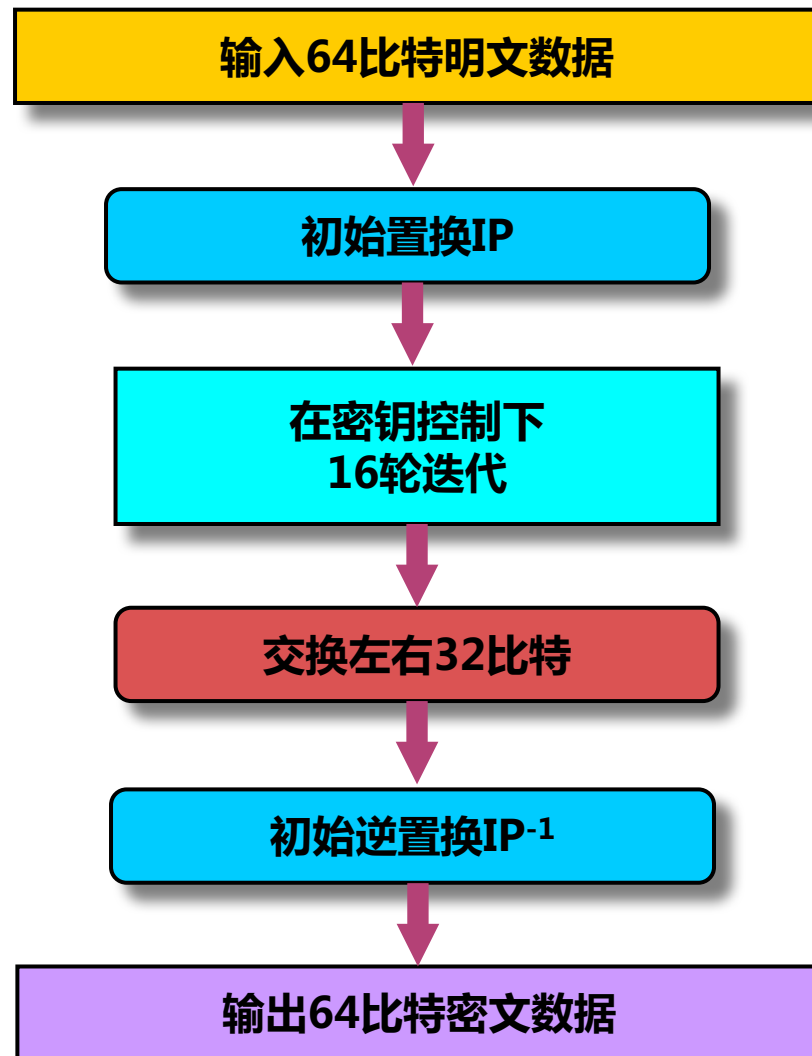
著名对称加密算法

- 对称加密的密钥长度从40bits到168bits
- 著名加密算法
 - DES 3DES
 - AES
 - RC系列 (RC2、RC4、RC5)
 - IDEA
 - CAST
 - Blowfish

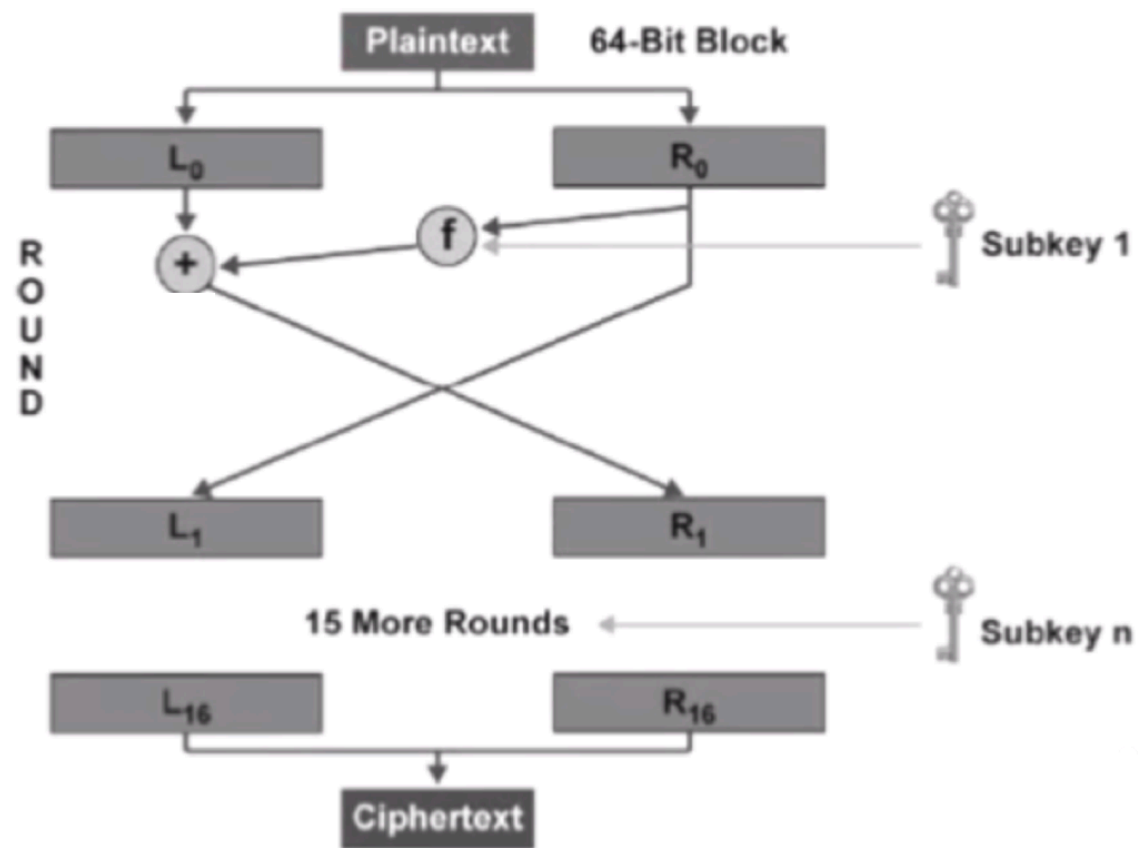
DES (Data Encryption Standard)

- DES是一种块或分组加密算法
- 20世纪70年代，由IBM公司发明
- 1976年11月纳为美国国家标准
- DES密钥是固定的56bit，不安全
- DES以块模式对64bit的密文块进行操作

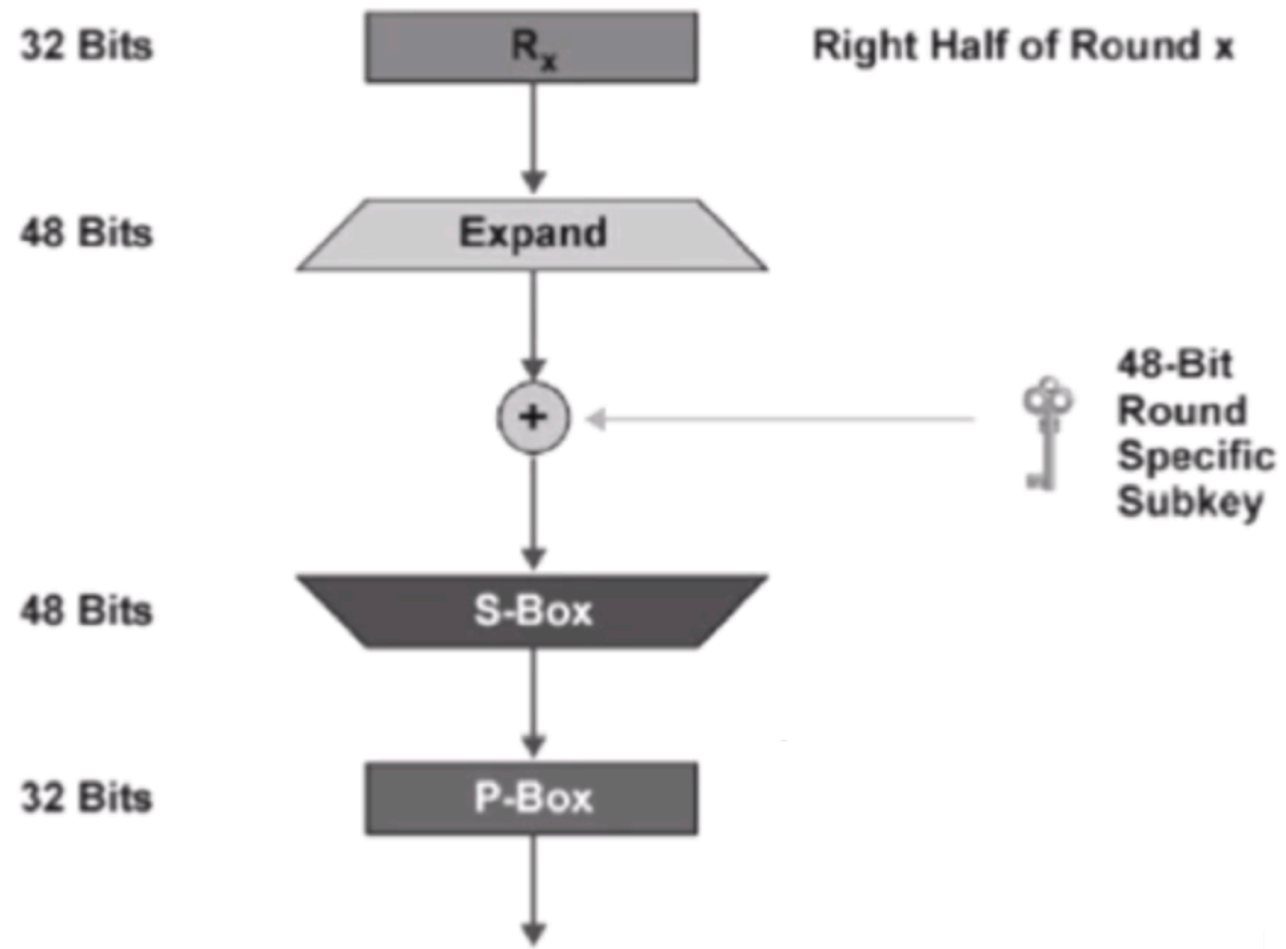
DES 算法框架图



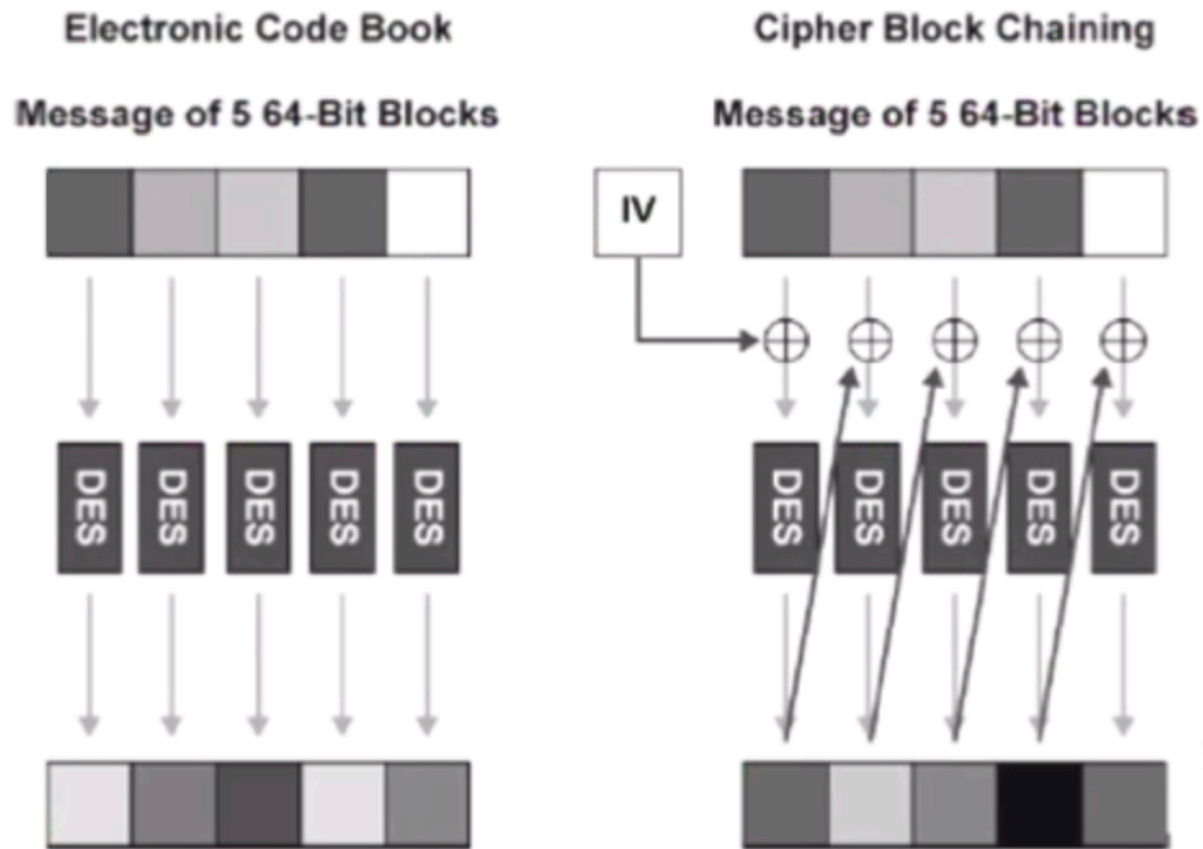
DES 密码分组公式



DES 密码分组公式



DES ECB vs CBC Mode



问题：相同明文得到相同密文

三种攻击：统计学，尝试，部分解密

DES 总结

- 56bit的DES太短，不安全，需要经常修改密钥，防止暴力破解
 - 没有漏洞，只能暴力破解 2^{55}
 - WEP有108位密钥，但有漏洞，很快算出
- 需要在一个安全的信道交换DES密钥
- 使用DES的CBC模式

3DES 安全，但会增加延时，语音视频不适用

- 3DES (Triple DES) 密钥长度放大3倍，168位
- 暴力破解几乎不能实现
- 底层基于一个很好的算法
- 安全，但会增加延时，语音视频不适用



AES (Advanced Encryption Standard)

- 1997年被颁布，取代DES的加密算法
- 比利时的Joan Daemen和Vincent Rijmen发明，“Rain Doll”
- 适合于高速网络，适合在硬件上实现
- 使用128位、192位或256位的密钥块（还能以32bit扩展）
- 3DES的替代加密技术，软硬件运行效率高，可用于无线/语音视频加密

RC系列加密算法

■ RC2

- Ronald Rivest设计
- 密钥长度可变
- RC2的运算速度比DES快
- 软件实现的RC2比DES快三倍
- RC2是否比DES安全取决于其所使用的密钥长度

■ RC4

- Rivest设计
- 密钥长度可变
- 流模式加密算法，面向bit操作
- 算法基于随机置换
- RC4应用范围广 (<https://WEP/WPA>) WPA2-AES

■ RC5

- Rivest设计
- 分组长、密钥长和迭代轮数都可变
- 面向字结构，便于软件和硬件快速实现
- 数据相倚旋转技术

- IDEA，国际数据加密算法
- 分组长度为64位，密钥长度为128位
- 设计原则：来自不同代数群的混合运算
 - 异或
 - 模216加
 - 模216 + 1乘

- 64位数据首先分成4个16-位子分组作为第一轮☐的输入
- 总共8轮计算
- 每轮中，4个子分组相互之间相异或，相加，相乘，且与6个16位子密钥相异或，相加，相乘
- 轮与轮之间，第二个和第三个子分组交换。最后在输出变换中4个子分组与4个子密钥进行运算
- IDEA共使用52个子密钥
- 软件实现的IDEA比DES快两倍

Blowfish

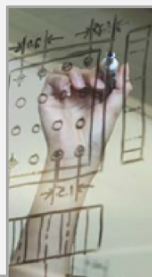
- Bruce Schneier设计
- 密钥长度可变
- 易于软件快速实现，所需存储空间不到5KB
- 安全性可以通过改变密钥长度进行调整
- 适用于密钥不经常改变的加密
- 不适用于需要经常变换密钥的情况

- 完备的用户行为跟踪记录
- 支持基于广域网的端点准入防御功能（EAD）
- 精细化的业务识别和控制
 - 应用识别和控制，支持多种应用的识别，包括citrix、dhcp、dns、exchange、ftp、sip和http等在内的近百种协议
 - 网络流量监控，对网络转发流量进行统计和报表

完备的VPN网络构建能力

- 支持丰富和全面的VPN技术，包括IPsec、L2TP、GRE、ADVPN（Auto Discovery VPN）和GDVPN^[*]（Group Domain VPN），同时支持国密办加密算法
- 支持多种应用场景下的VPN组网：

电子政务里面 SM1 SM2不能出口

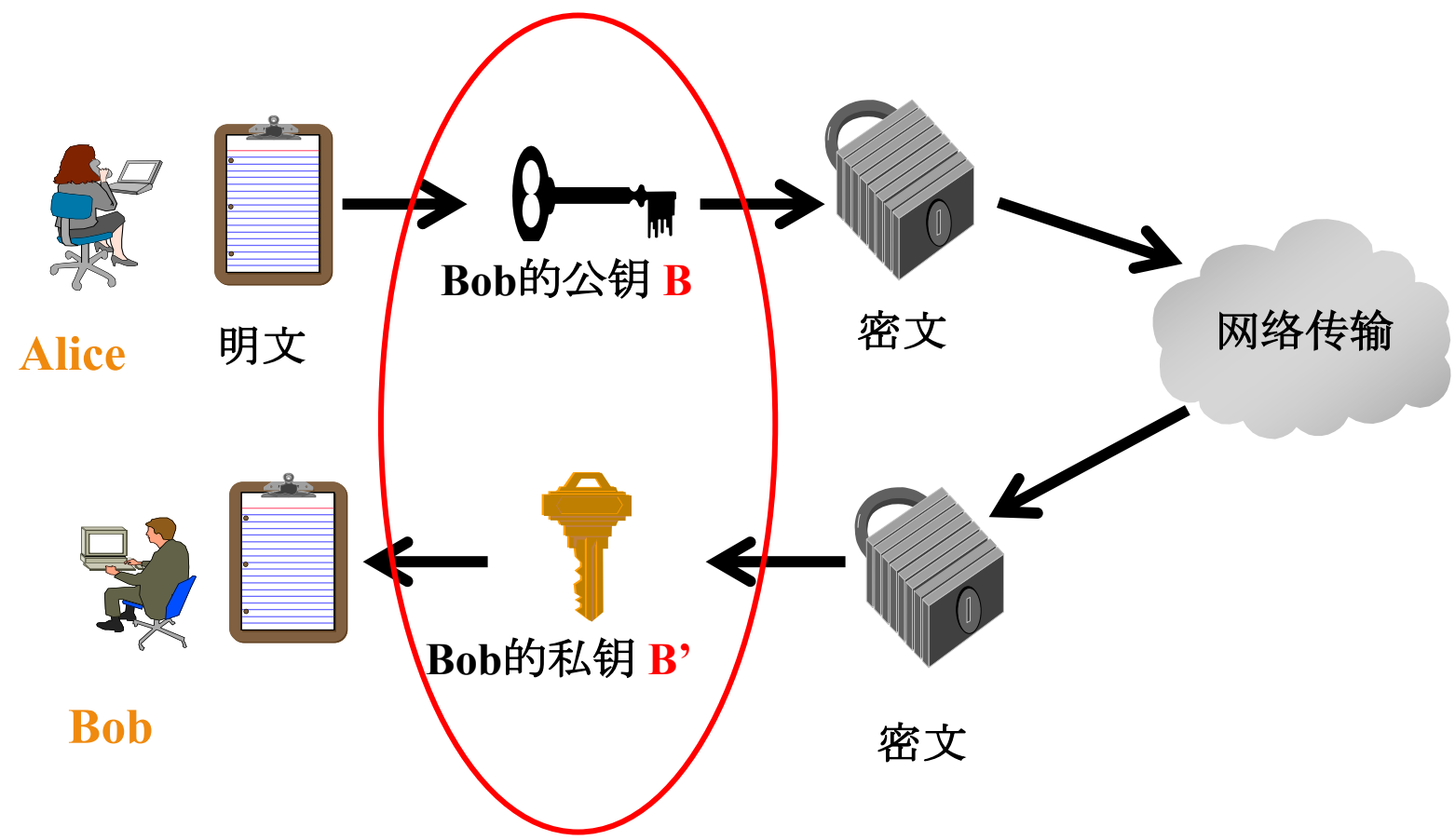


非对称/公钥加密算法

公钥加密技术（非对称加密技术）

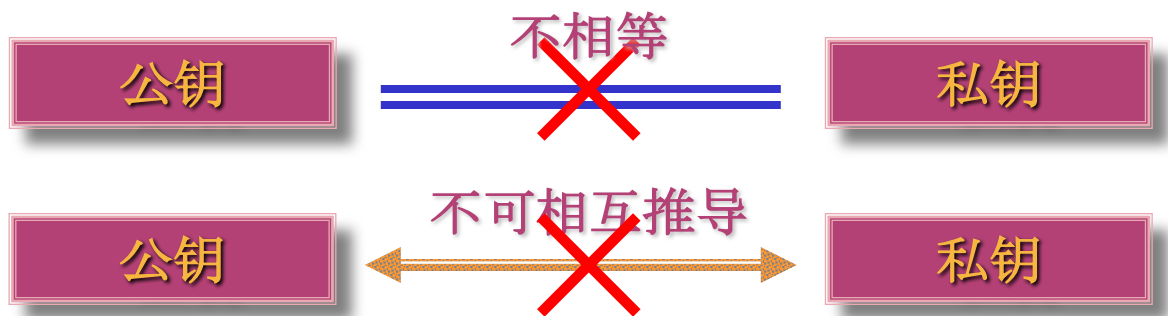
- 公钥加密比私钥加密出现晚
 - 私钥加密使用同一个密钥来加密和解密信息
 - 公钥加密使用两个密钥，一个密钥用于加密信息，另一个密钥用于解密信息
-
- 公钥加密，私钥解
 - 公钥加密，公钥不能解
 - 私钥加密，私钥不能解
-
- 应用：公钥加密，保密性 私钥签名：数字签名

公钥加密算法（非对称加密算法）



公钥加密算法（非对称加密算法）

- 私钥需要安全保存（不通过网络传送）
- 公钥公开
- 加密速度慢，密文非紧凑
- 可以与对称加密相结合



非对称加密算法

- RSA
- DH (Diffie-Hellman)
- DSA
- ECC

公钥密码系统的应用

- 三种用途：
 - 加密/解密
 - 数字签名：发送方用自己的私钥签署报文，接收方用对方的公钥验证对方的签名
 - 密钥交换：双方协商会话密钥

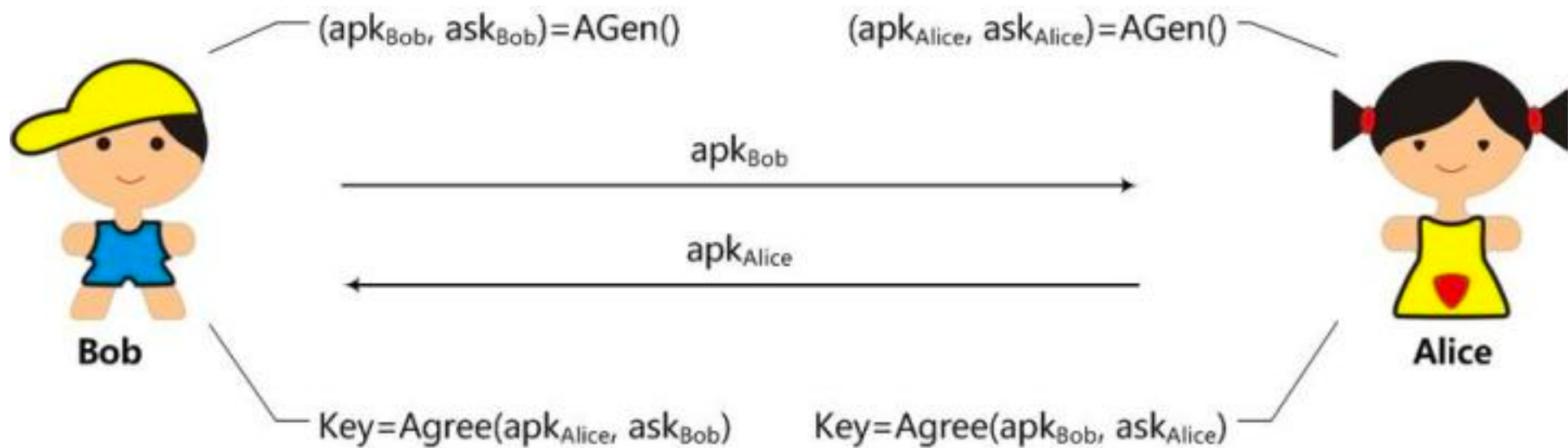
算法	加密/解密	数字签名	密钥交换
RSA	Y	Y	Y
Diffie-Hellman	N	N	Y
DSA	N	Y	N

Diffie-Hellman密钥交换

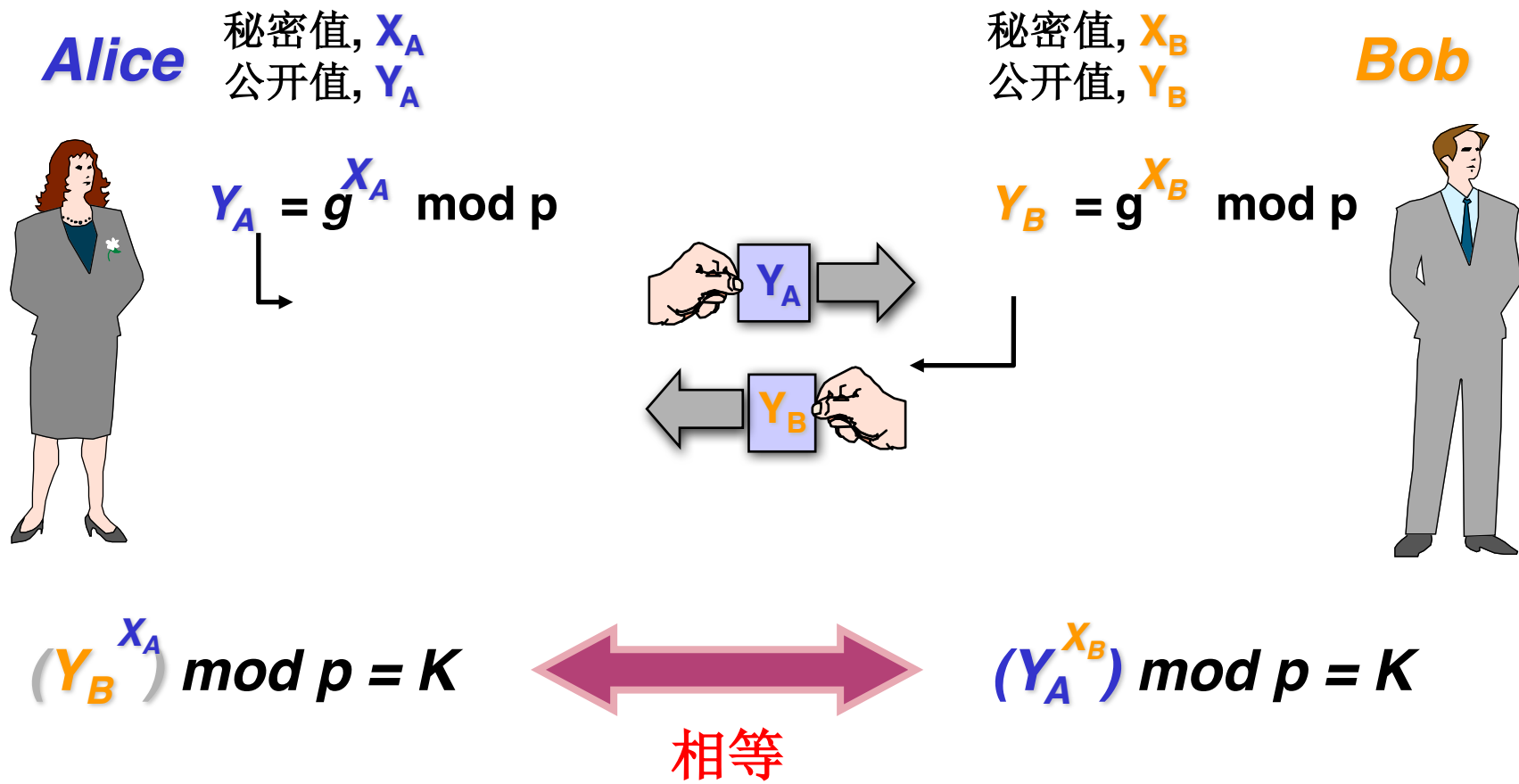
- 1976年，Whitfield Diffie和Martin Hellman发明
- 解决对称加密系统中密钥的发布问题
- 无需使用代价高昂即可对私钥达成共识
- 安全性来源于很难计算出很大的离散对数
- 在现代密钥管理中提供其他算法的密钥管理

Diffie-Hellman密钥交换

- 密钥生成算法AGen输出一个公钥和私钥对(apk , ask)， ask 需要秘密地保存， apk 可以公开发送给对方。
- 密钥协商算法Agree以一方的公钥 apk 和自己的私钥 ask 作为输入，计算出一个密钥 K 。



Diffie-Hellman密钥交换



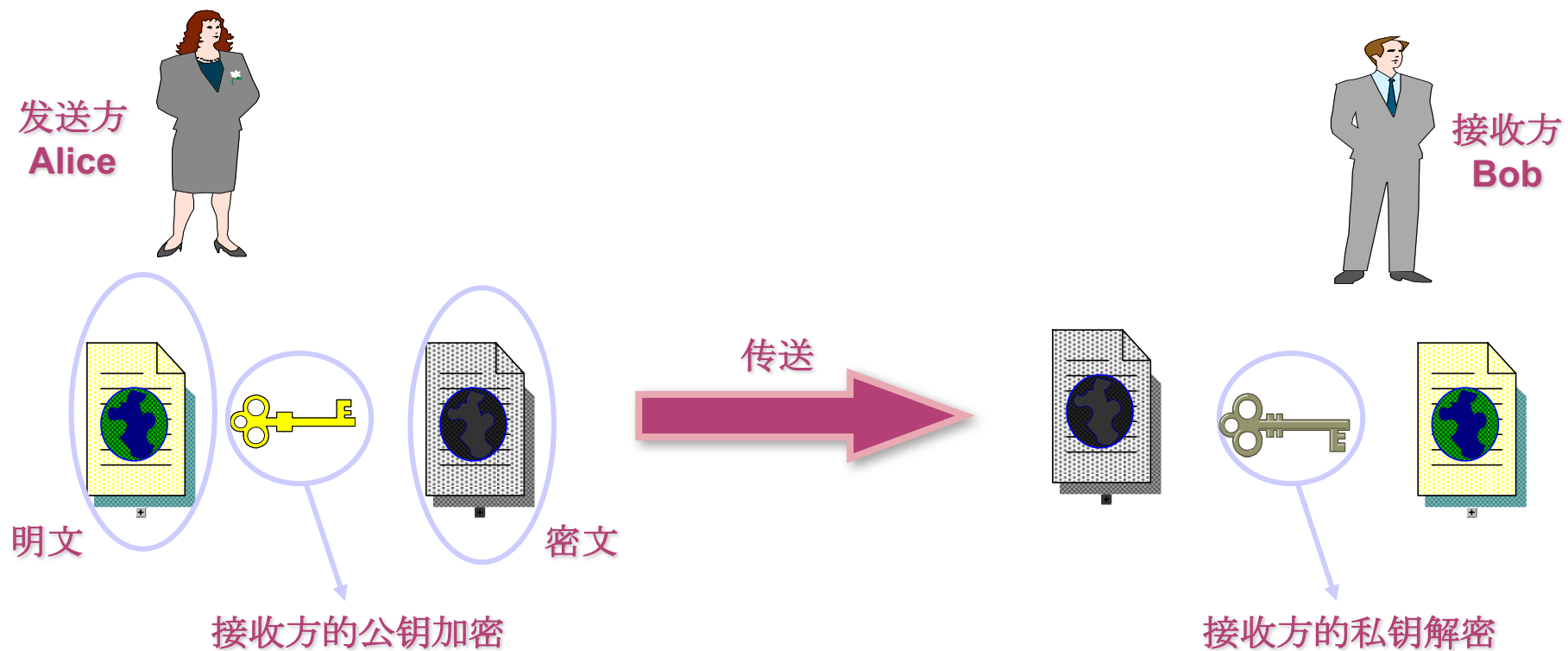
Diffie-Hellman密钥交换

- Diffie-Hellman可行之处：
 - 产生共享密钥需要一个保密值，外人无法得到
 - 计算大数的离散对数很困难

- 1977年由Ron Rivest、Adi Shamir和Len Adelman开发
- 专利于2000年9月到期
- 密钥长度在512~4096bit之间
- 安全性基于大素数因子分解的困难性

- RSA比用软件实现的DES慢100倍
- RSA比用硬件实现的DES慢1000倍
- RSA的主要功能：加密、数字签名和密钥交换（加密散列、密钥）

RSA提供保密性（公钥加密）



其他公钥算法

■ Elgamal

- Taher Elgamal开发
- Diffie-Hellman的一种变形
- 可以加密和提供认证
- 安全性取决于计算离散对数的难度

■ 椭圆曲线加密

- 1985年提出
- 原理：给定椭圆曲线上的两点A和B，如 $A = kB$ ，要找到整数k非常困难
- 密钥更小：与1024位RSA密钥具有同样安全性的ECC密钥只有160位

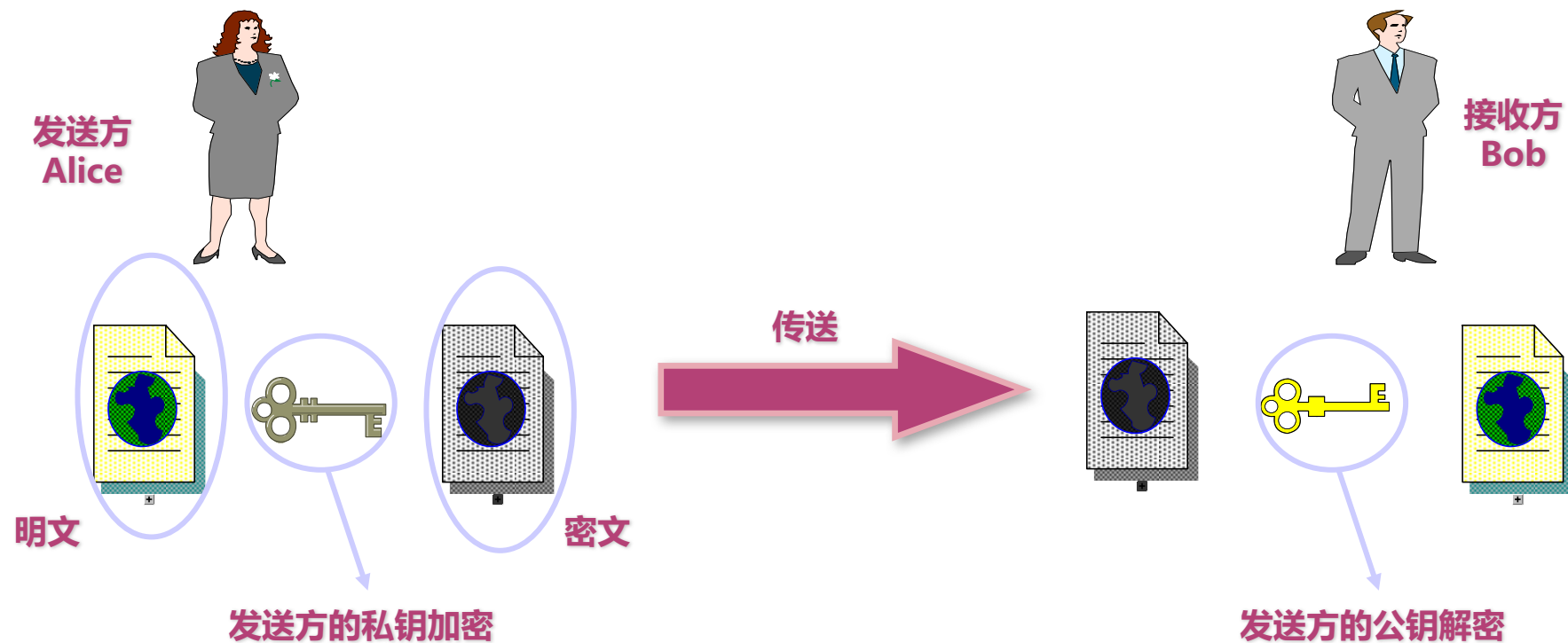
■ 数字签名算法

- 由美国政府开发
- 数字签名的标准算法。
- 算法基于Elgamal
- 只允许认证，不能提供保密性

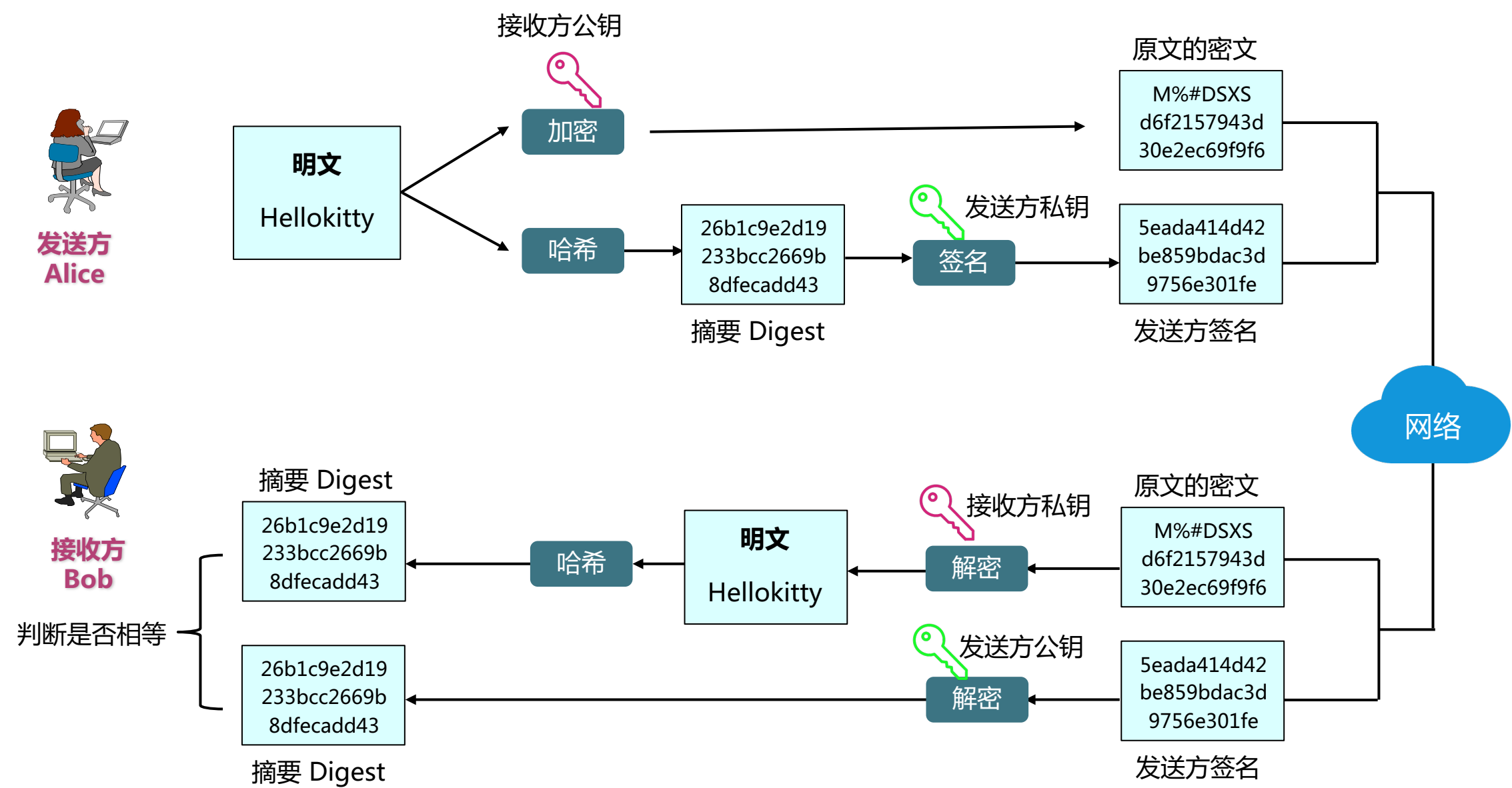


数字签名

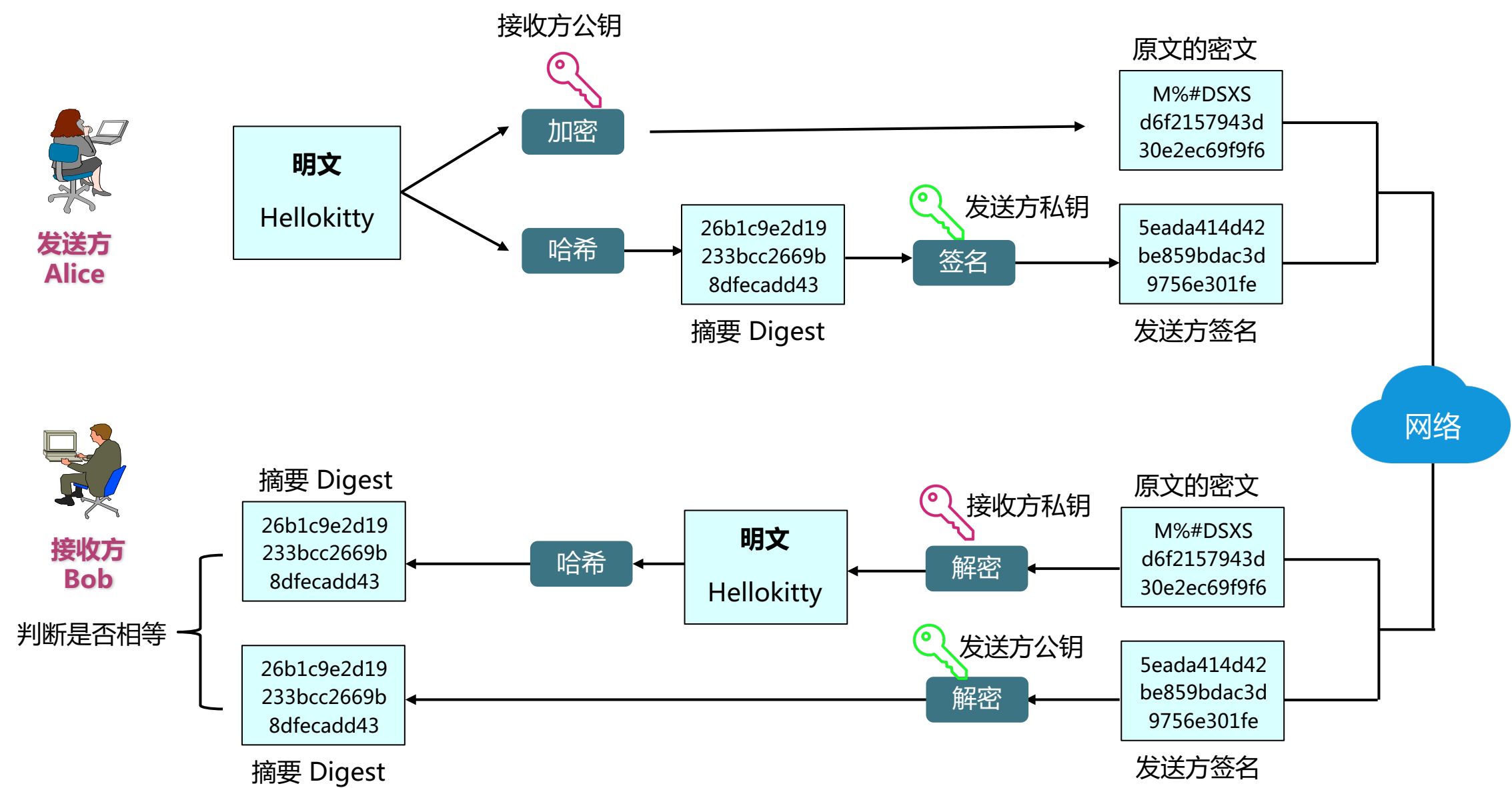
RSA提供认证和抗抵赖（私钥签名）



数字签名 Digital Signature



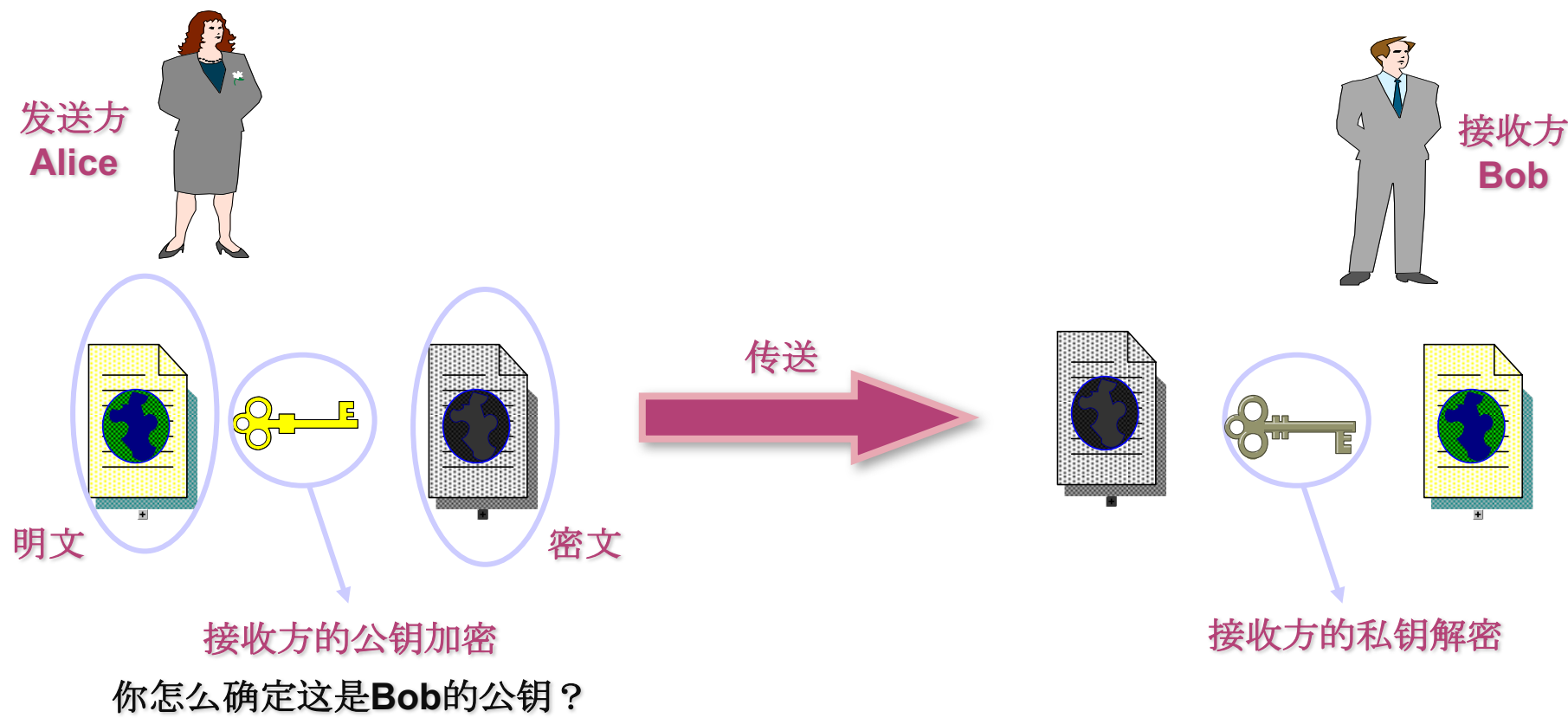
数字签名 Digital Signature





数字证书与CA

数字证书与CA

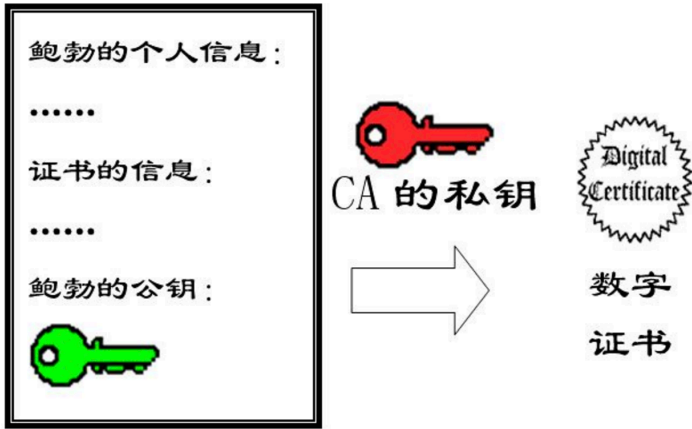


数字证书与CA



有公安防伪标记（签名），证明你的身份证号为XXX

数字证书（Digital Certificate，类似身份证的作用）
CA（Certificate Authority，电子商务认证授权机构）



有CA数字签名的，证明绿色是Bob公钥

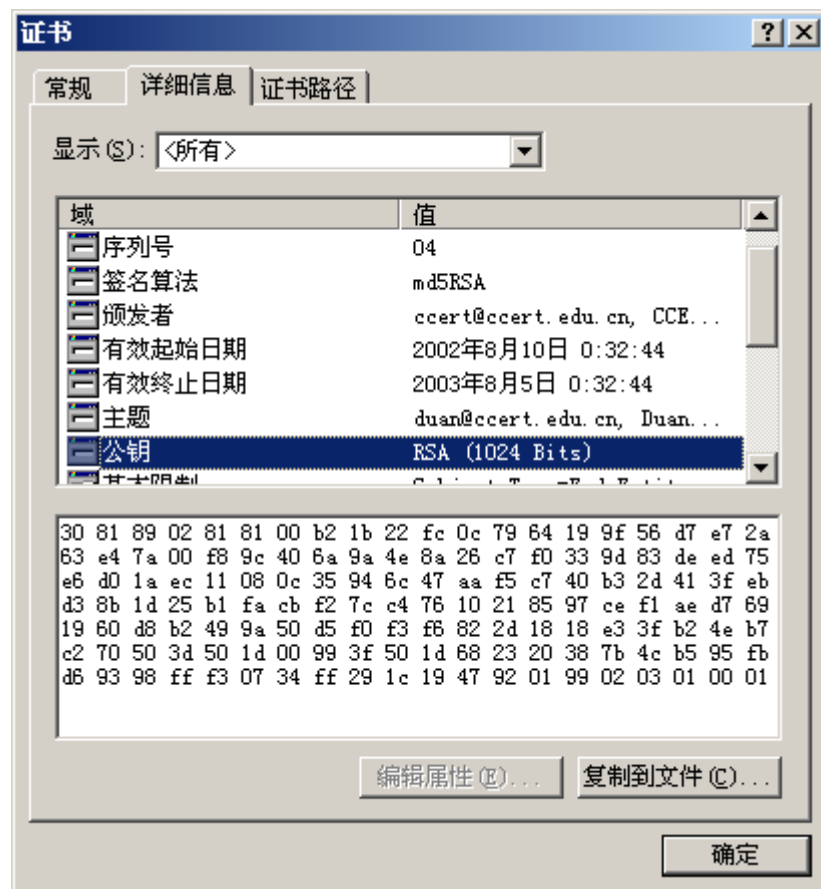
数字证书	
姓名，地址，组织	所有者公钥
证书有效期	认证机构数据签名

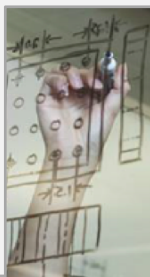
公钥证书实例

■ 公钥证书的种类与用途

- CA
- Personal
- Code Signing
- Server

■ 证书回收列表 (CRL)





哈希与HMAC

哈希 Hash (也叫散列函数) MD5 SHA

- 将一段数据 (任意长度) 经过一道计算 , 转换为一段定长的数据
 - <http://www.fileformat.info/tool/hash.htm>
- 不可逆性 (单向) 几乎无法通过Hash结果推导出原文 , 即无法通过x的Hash值推导出x
- 无碰撞性 几乎不可能找到一个y , 使得y的Hash值等于x的Hash值
- 雪崩效应 输入轻微变化 , Hash输出值产生巨大变化
- 使用场景
 - 发布文件的完整性验证 , 如炒股软件+MD5
 - <http://download.cs.ecitic.com> MD5 : 608756CEA9639AD5514E3E6014B623B1
 - 服务器中保存用户的密码
 - 数字签名

哈希用例 用户密码的存储

1. 明文存储，无安全防护

用户名	密码
test	123456

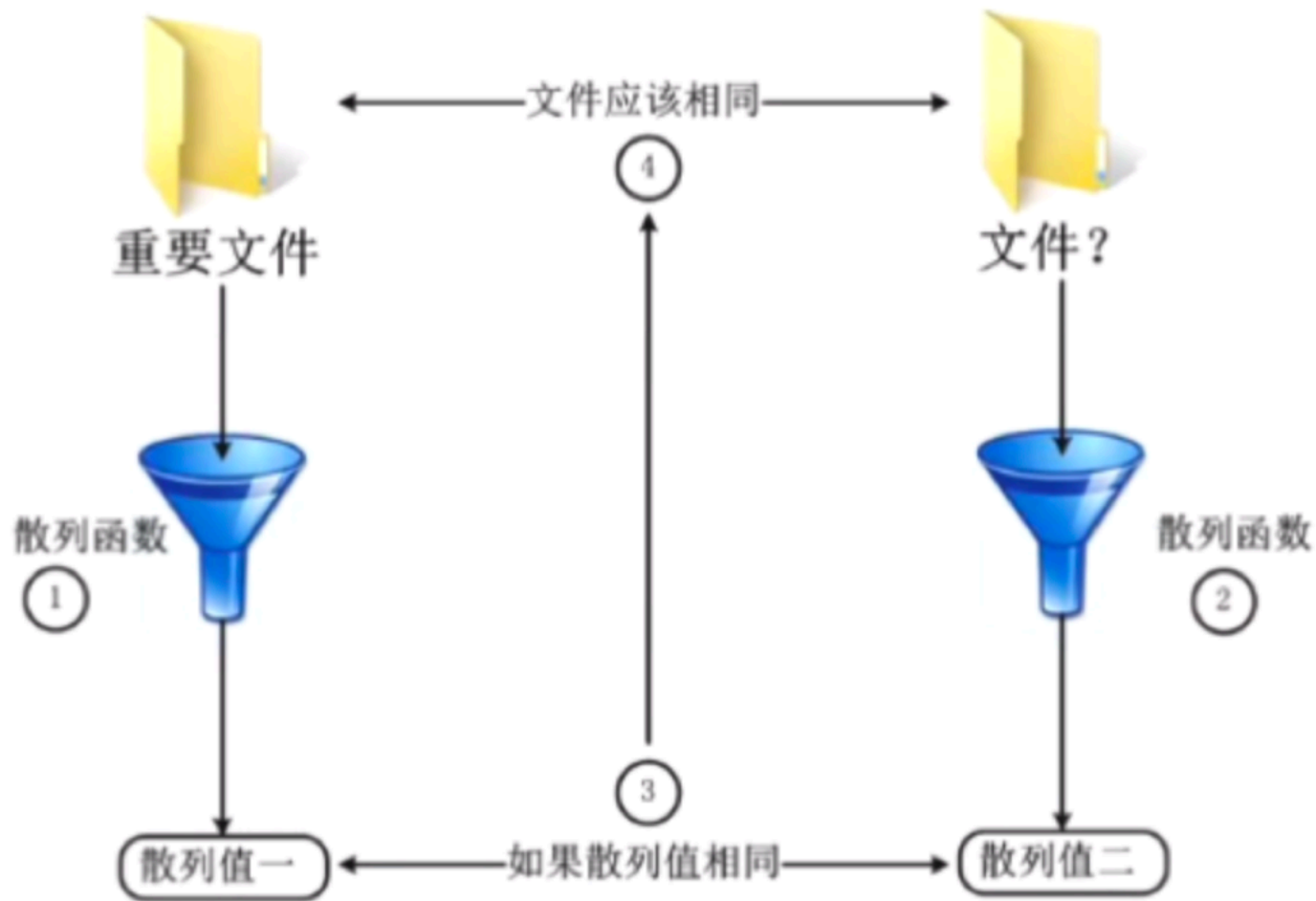
2. 哈希存储（Rainbow Table Attack，彩虹表攻击）

用户名	密码
test	e10adc3949ba59abbe56e057f20f883e

3. （盐+哈希）存储（彩虹表攻击 失效）

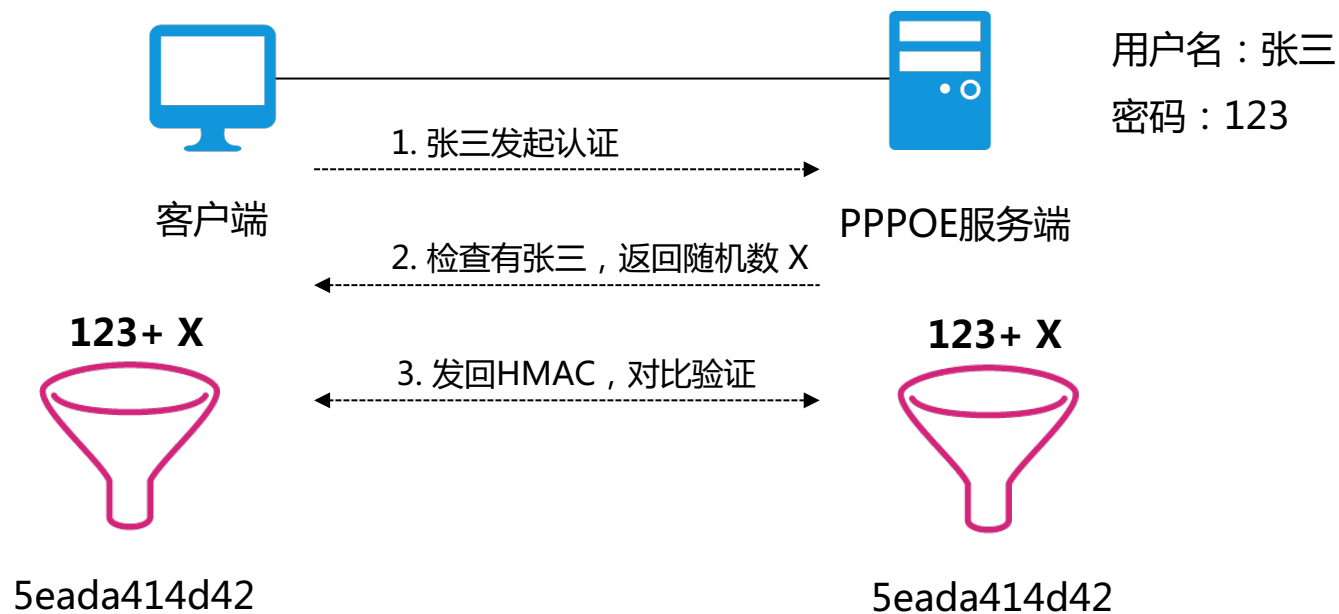
用户名	盐	密码
test	2018-2-20 20:08:23	d8e423a9d5eb97da9e2d58cd57b92808

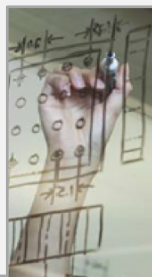
哈希 Hash (也叫散列函数) MD5 SHA



HMAC

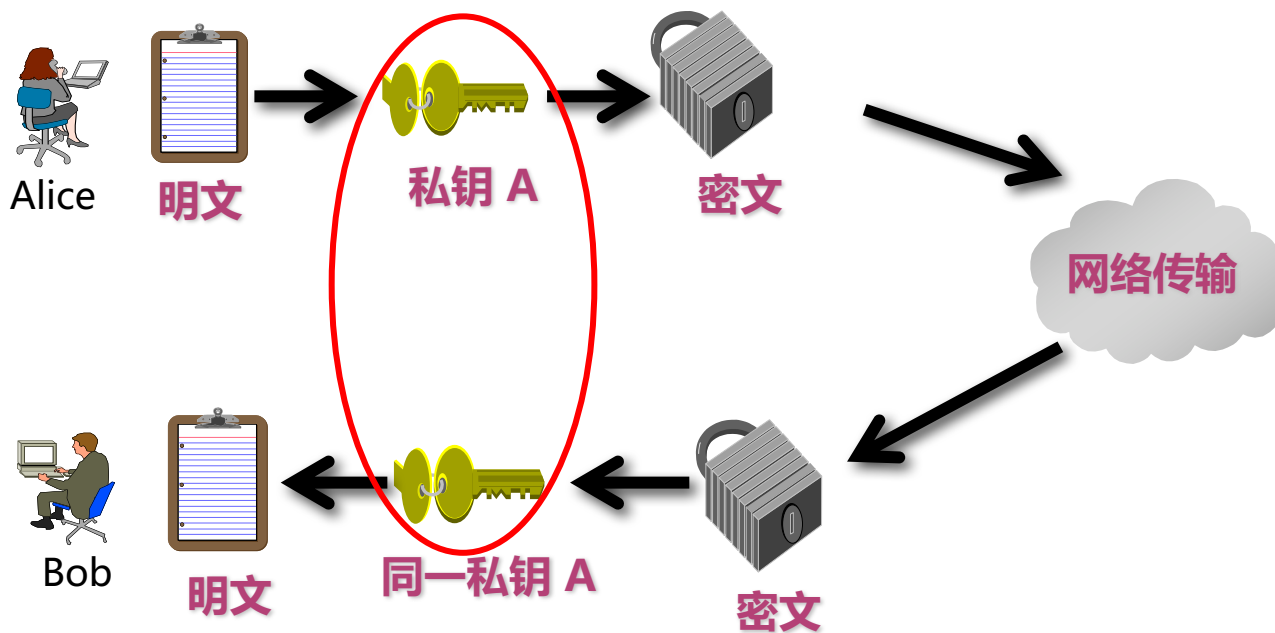
- 增加一个key做哈希。HMAC = Hash (文件+key)
- 需要双方预先知道这个key
- HMAC：消除中间人攻击，源认证+完整性校验（数字签名也能实现）



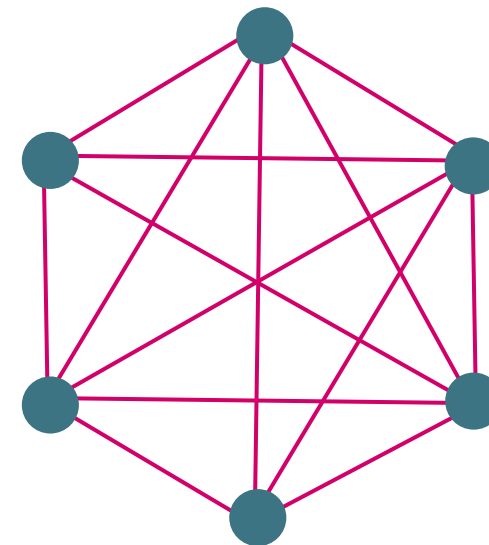


对称与非对称加密完美融合

对称加密算法的问题



Alice怎么把密钥传递给Bob？
坐飞机去取？网络传送？打电话？ 窃听



2个人只有一个密钥，6个人则 $6 * (6 - 1) = 30$

100个人密钥数量就是 $100 * (100 - 1)$

而且为了保障安全，每个密钥使用一次后要删除

对称加密算法缺点：密钥分发、密钥存储和管理。缺乏对数字签名的支持。

非对称加密算法的问题

■ 优点：

- 不需要私钥传送，天然防窃听
- 每个人2个密钥，不会随着人数增加倍数增长
- 支持数字签名，抗抵赖性/认证

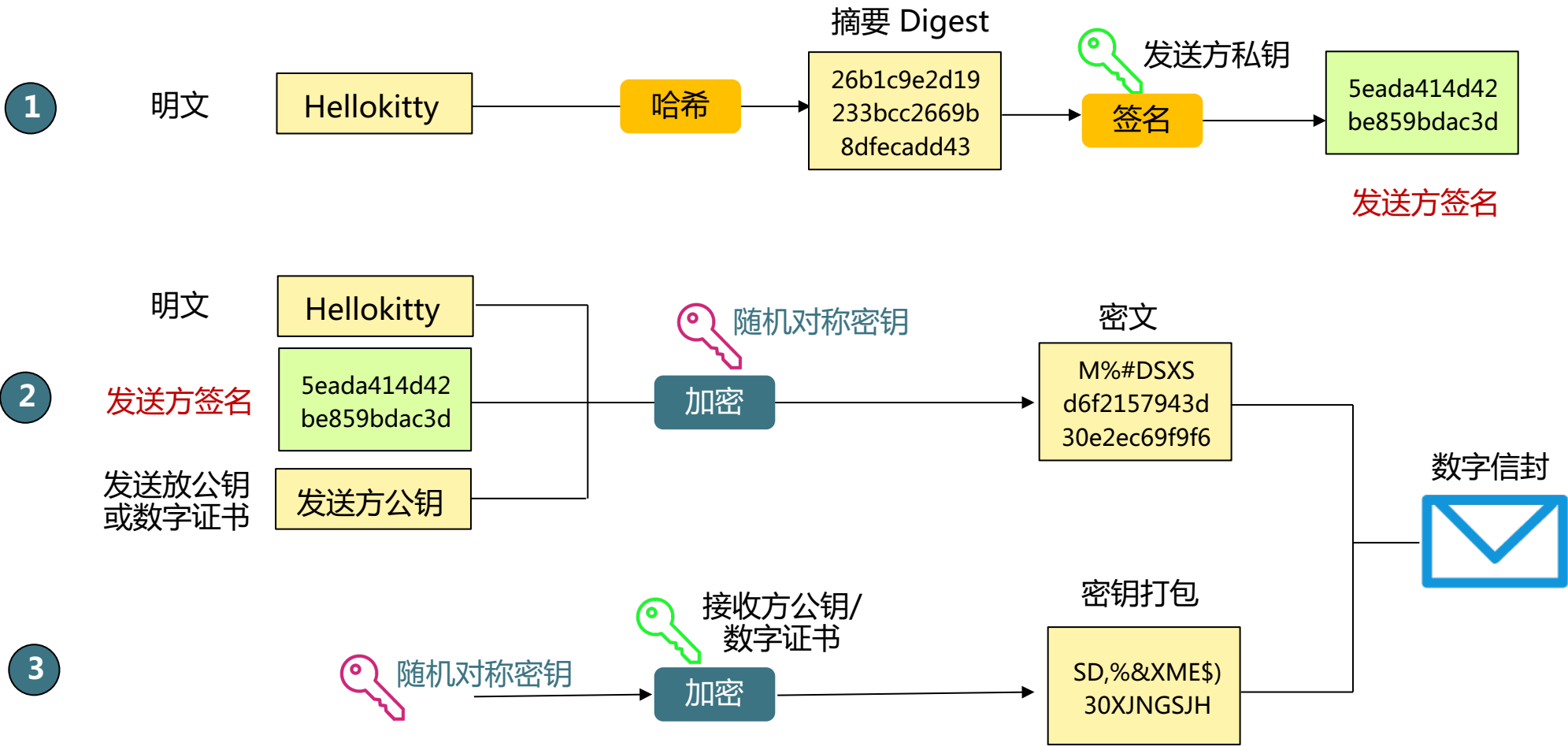
■ 缺点：

- 加密速度慢，密文非紧凑

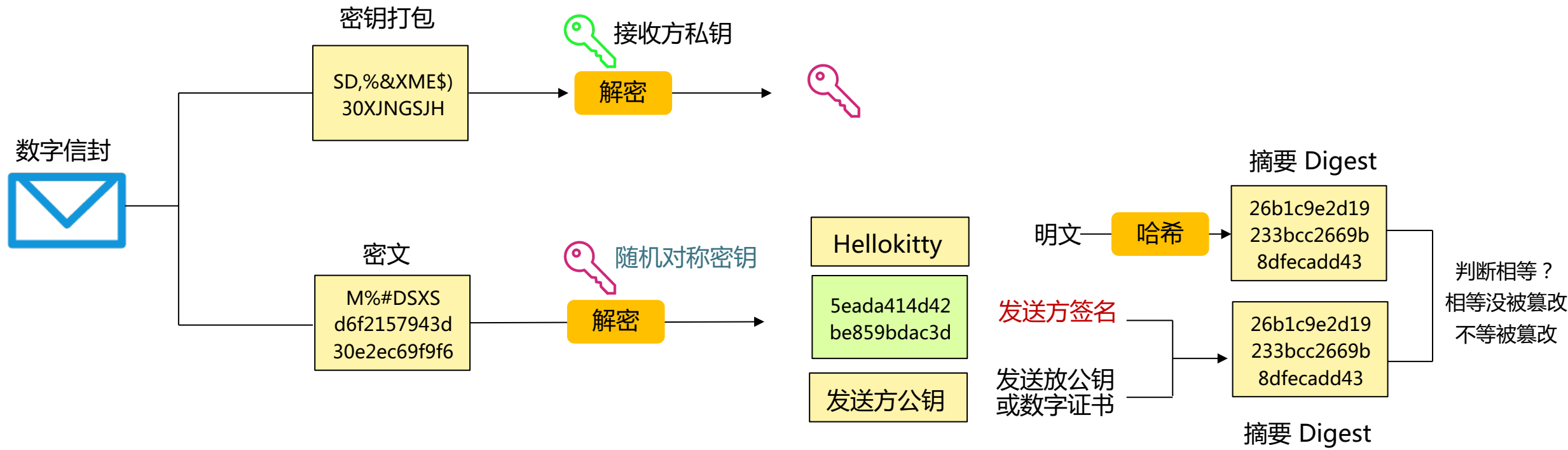
对称加密算法与非对称加密算法完美结合

对称加密算法对大文件进行加密，非对称加密算法对密钥加密

两全其美的加解密解决方案 发送方操作123



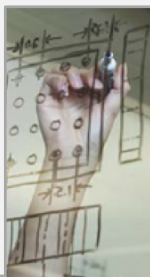
两全其美的加解密解决方案 接收方操作321



通过对称加密和非对称加密算法的结合使用，解决了

- 1. 数据快速加解密，且紧凑（对称加密算法）
- 2. 确定数据一定是A发的（数字签名，不可否认）
- 3. 确定数据传输过程没有经过篡改（哈希算法）

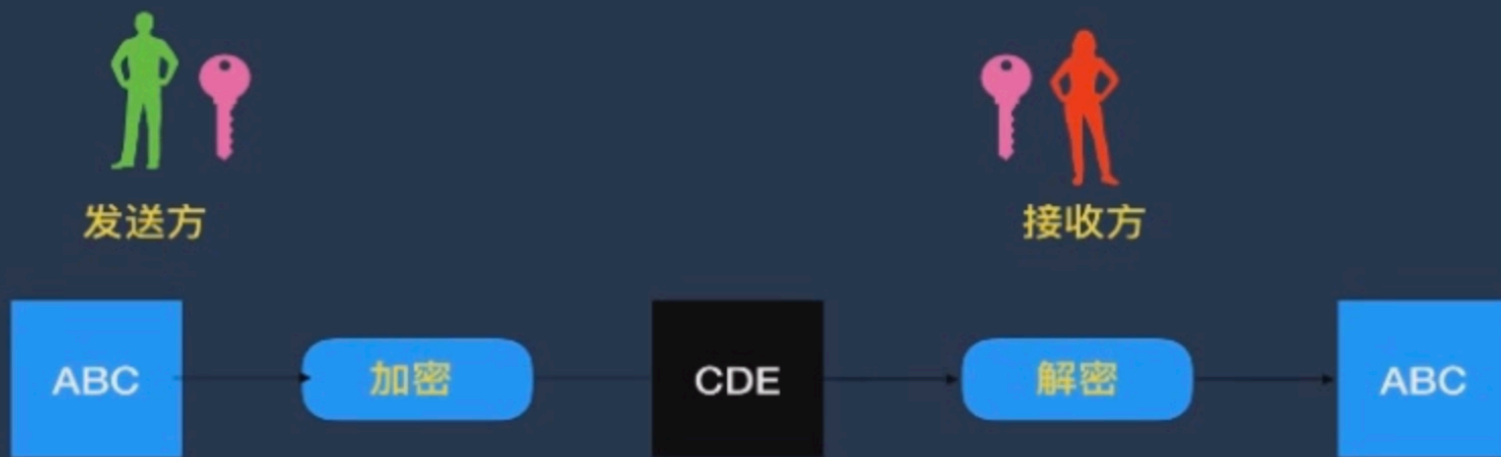
用发送方公钥解签名
能解开证明确定是A发送
不能解开证明不是A发送



密码学原理总结

对称加密

- ❖ 用相同密钥对原文进行加密和解密
- ❖ 加密过程： 密钥 + 原文 $\Rightarrow$ 密文
- ❖ 解密过程： 密文 - 密钥 $\Rightarrow$ 原文
- ❖ 缺点： 无法确保密钥被安全传递



非对称加密 – 公钥&私钥



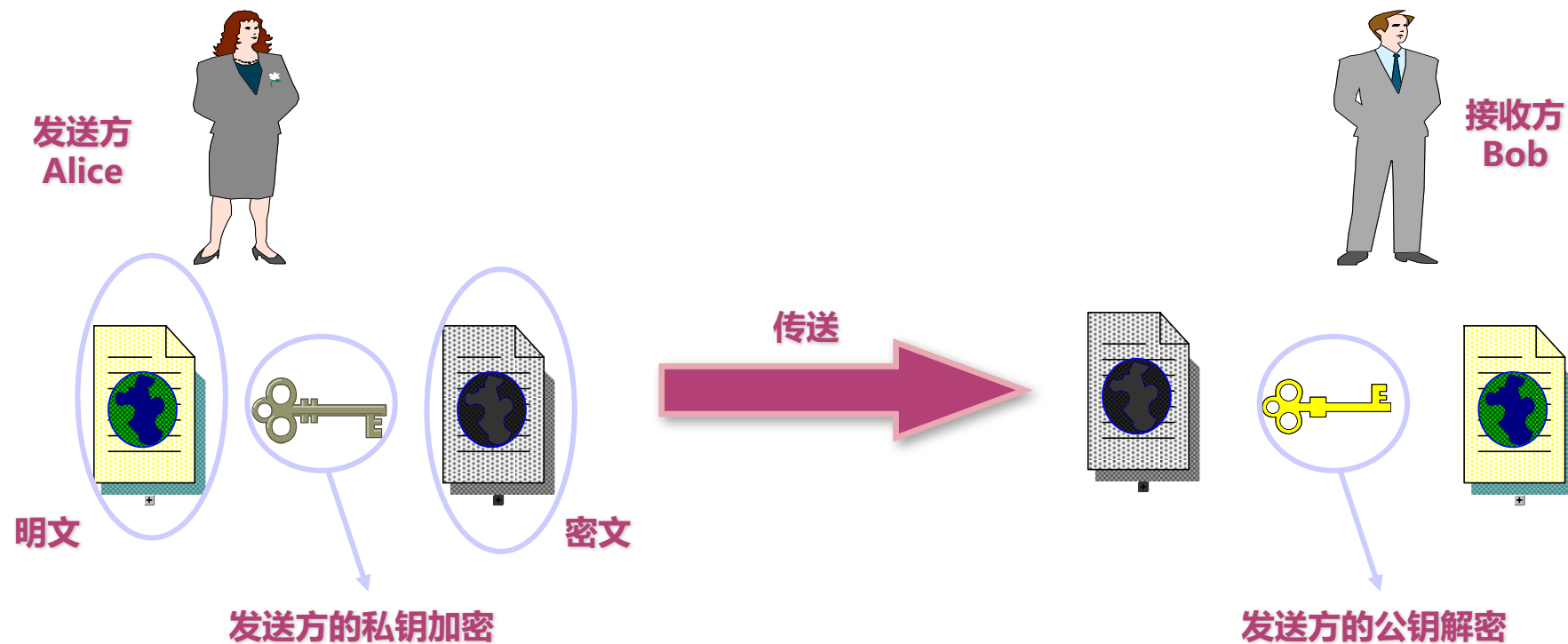
- ❖ 公钥用于加密，私钥用于解密
- ❖ 公钥由私钥生成，私钥可以推导出公钥
- ❖ 从公钥**无法**推导出私钥
- ❖ 优点：解决了密钥传输中的安全性问题
- ❖ 解决了信息传送的问题，如何验证是“**确实是发送方发送的**，信件没有被篡改”？



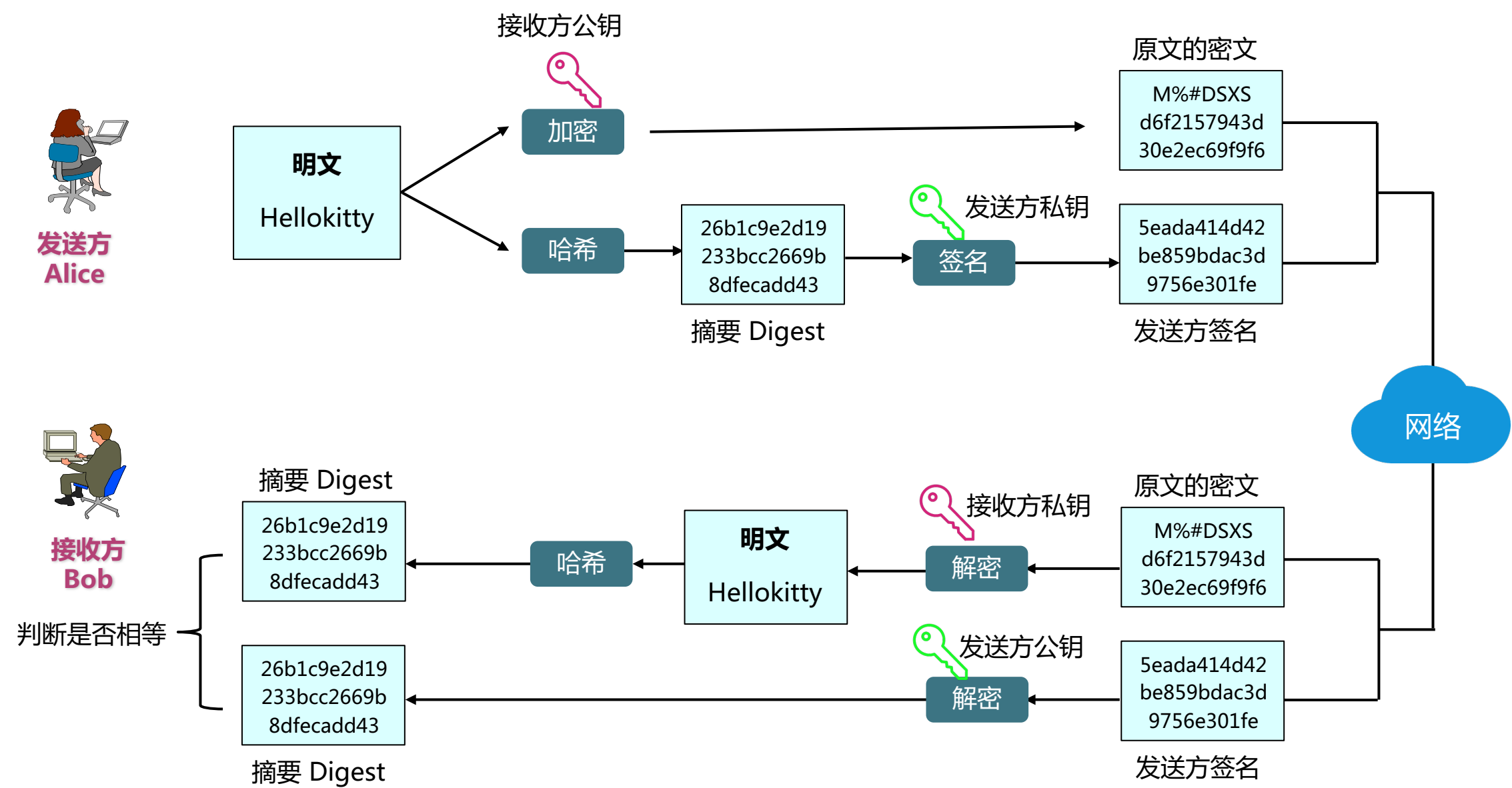
哈希 Hash (也叫散列函数)

- 将一段数据 (任意长度) 经过一道计算 , 转换为一段定长的数据
 - <http://www.fileformat.info/tool/hash.htm>
- **不可逆性** 几乎无法通过Hash结果推导出原文 , 即无法通过x的Hash值推导出x
- **无碰撞性** 几乎没有可能找到一个y , 使得y的Hash值等于x的Hash值
- **雪崩效应** 输入轻微变化 , Hash输出值产生巨大变化
- 使用场景
 - 发布文件的完整性验证 , 如炒股软件+MD5
 - <http://download.cs.ecitic.com> MD5 : 608756CEA9639AD5514E3E6014B623B1
 - 服务器中保存用户的密码
 - 数字签名

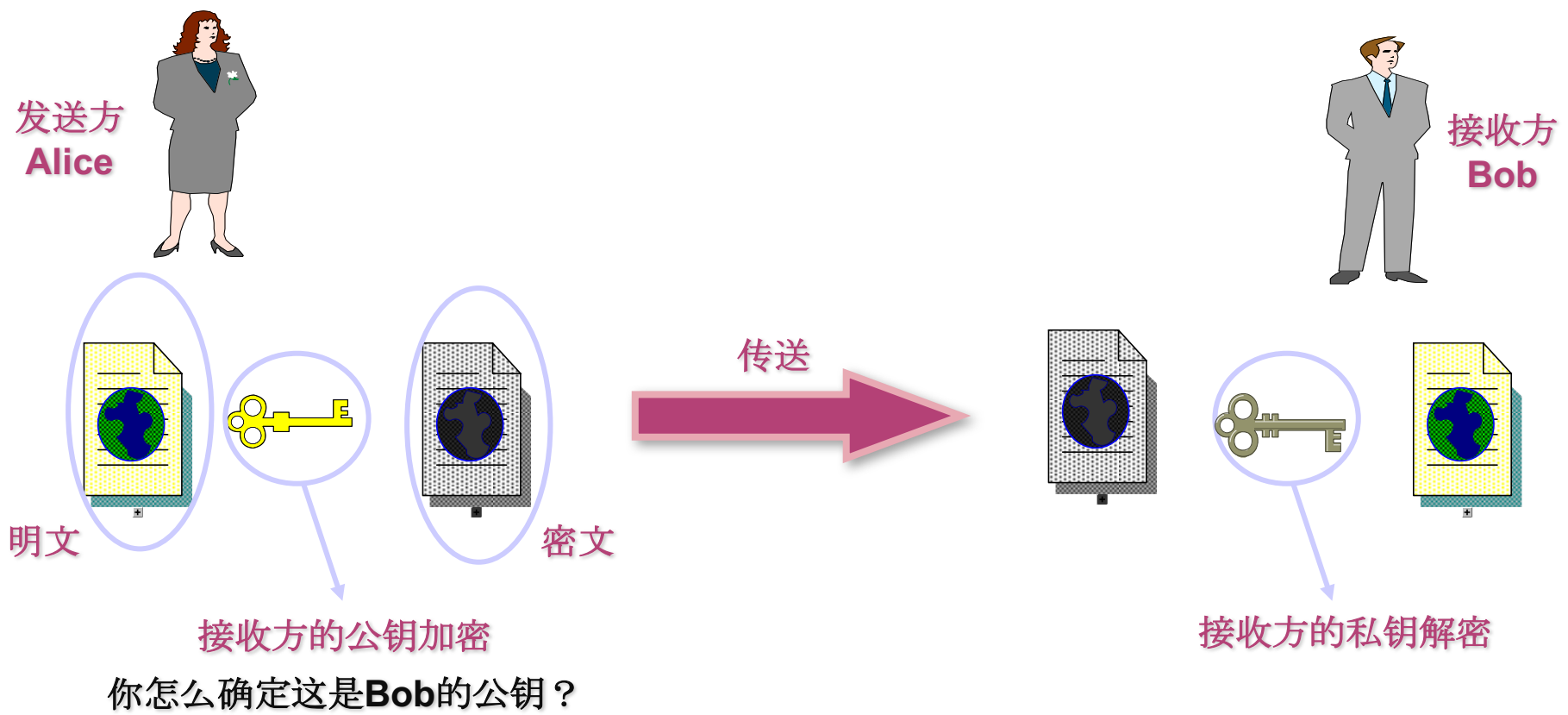
RSA提供认证和抗抵赖（私钥签名）



数字签名 Digital Signature



数字证书与CA

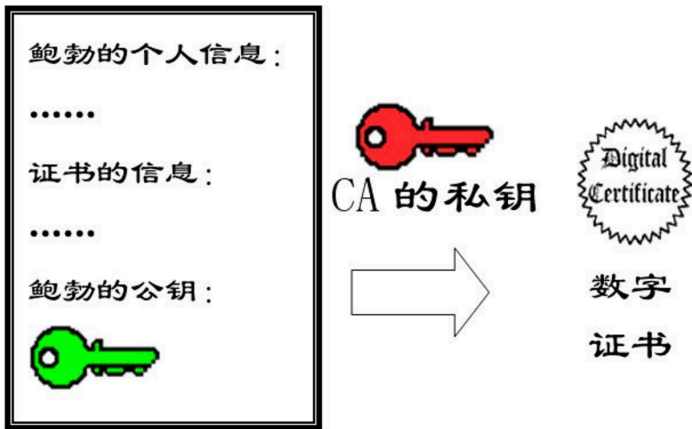


数字证书与CA



有公安防伪标记（签名），证明你的身份证号为XXX

数字证书（Digital Certificate，类似身份证的作用）
CA（Certificate Authority，电子商务认证授权机构）



有CA数字签名的，证明绿色是Bob公钥

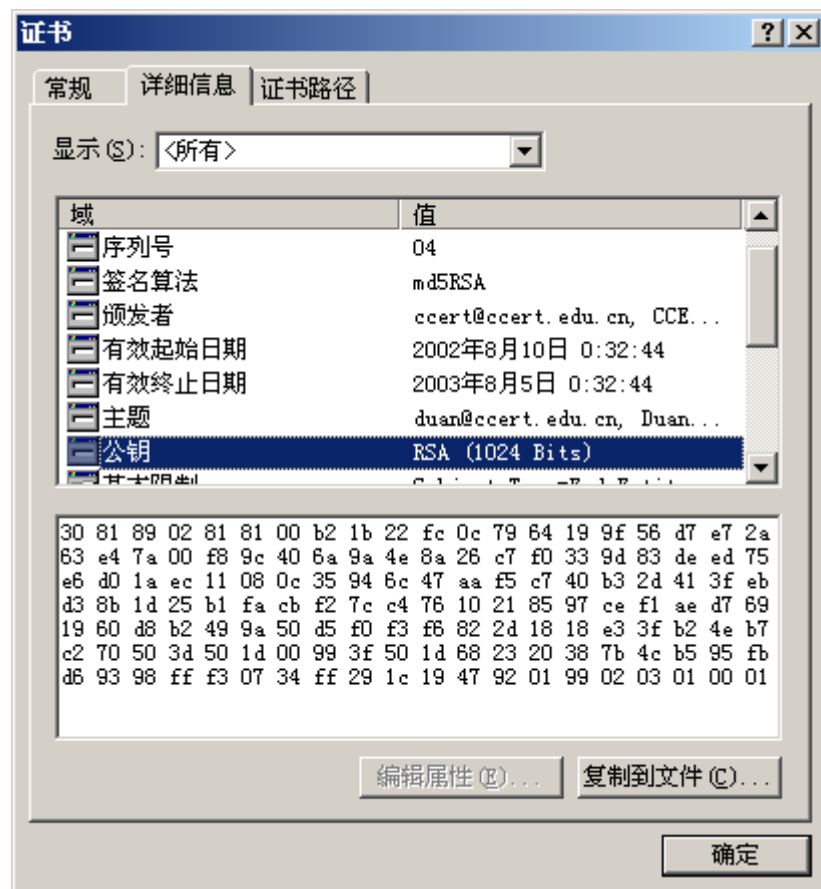
数字证书	
姓名，地址，组织	所有者公钥
证书有效期	认证机构数据签名

公钥证书实例

■ 公钥证书的种类与用途

- CA
- Personal
- Code Signing
- Server

■ 证书回收列表 (CRL)



加解密相关术语

- 明文 也叫明码 (plaintext)
- 密文 (ciphertext)
- 算法 (algorithm)
- 密钥 (key)
- 加密 (encryption)
- 解密 (decryption)
- 公钥 (public key)
- 私钥 (private key)
- 数字签名 (digital signature)
- 证书 (certificate)
- PKI (Public Key Infrastructure)
- HASH HMAC

| THANKS 「授人以渔」

- 跨界。 马克思。、 中本聪。 Core与比特大陆美国与中国

区块链 80 和 443

密码学： 人不能太功利。 VPN 区块链。 黑客。 Ca公司。